



Federal Office
for Information Security

5G Risk Analysis

Detailed Analysis: **IP Multimedia Subsystem (IMS) and Interconnect Network**



Version History

<i>Version</i>	<i>Date</i>	<i>Name</i>	<i>Description</i>
1.0	20.02.2025	Deloitte, BSI	Final Version

Table of Contents

1	List of Abbreviations	5
2	Introduction and Purpose	7
2.1	Intention	7
2.2	Link to Framework Document.....	7
3	Methodology.....	8
4	5G Network Model: IMS and Interconnect	10
4.1	IP Multimedia Subsystem (IMS).....	10
4.1.1	Proxy Call Session Control Function (P-CSCF)	11
4.1.2	Interrogating Call Session Control Function (I-CSCF).....	11
4.1.3	Serving Call Session Control Function (S-CSCF)	12
4.1.4	Access Border Gateway Function (A-BGF)	12
4.1.5	Interconnect Session Border Controller (I-SBC).....	12
4.1.6	Home Subscriber Server (HSS)/Unified Data Management (UDM).....	12
4.1.7	Application Server (AS)	12
4.1.8	Charging Data Function (CDF).....	12
4.1.9	Breakout Gateway Control Function (BGCF).....	12
4.1.10	Interfaces and reference points	13
4.2	5G Interconnect Network.....	14
4.2.1	Security Edge Protection Proxy (SEPP)	15
4.2.2	Signaling Firewall	15
4.2.3	User Plane Function (UPF).....	15
4.2.4	Serving Gateway (SGW).....	15
4.2.5	Packet Data Network Gateway (PGW).....	16
4.2.6	Diameter Edge Agent / Diameter Routing Agent (DEA/DRA)	16
4.2.7	Interfaces and reference points	16
4.3	Summary.....	17
5	Risk Scenarios.....	18
5.1	Attack Paths and Risk Sources.....	19
5.1.1	Misconfiguration (AP1).....	19
5.1.2	Insufficient Access Controls (AP2).....	21
5.1.3	Implementation Flaw (AP3).....	21
5.1.4	Specification Weakness (AP4).....	23
5.1.5	Failure of Power Supply (AP5).....	23
5.1.6	Failure of Hardware Components or Unavailability of Spare Parts (AP6).....	24
5.1.7	Design & Architecture Flaws (AP7).....	25
5.2	Public Mobile Network Operator (MNO) Perspective	27

5.2.1	Emergency Call (TKG § 164)	27
5.2.2	Cell Broadcast (TKG § 164a)	29
5.2.3	Telecommunications Secrecy (TTDSG § 3).....	29
5.2.4	Emergency Preparedness (TKG § 184)	32
5.2.5	Regional Network Failure.....	33
5.2.6	Multi-Regional Network Failure	34
5.2.7	Failure of Mobile Service.....	34
5.2.8	Fraud.....	35
5.2.9	Subscriber Data Leak.....	38
5.3	User Perspective	41
5.3.1	Urgent Telephone Calls Not Possible.....	41
5.3.2	Authenticity of the Receiver of a Call	43
5.3.3	Integrity of Transmitted Data.....	44
5.3.4	User's Identity	46
5.3.5	Eavesdropping of a Communication	48
5.3.6	Slowing Down/Restricting the Connection.....	50
5.3.7	Connection Failure	52
5.3.8	Tapping or Altering of the Geographical Position	53
5.4	Private 5G Network Operator Perspective.....	55
5.4.1	Network Failure.....	55
5.4.2	Degraded Services / Connections	55
5.4.3	Information Disclosure.....	56
5.4.4	User Identities (Authenticity/Integrity).....	56
6	Risk Assessment Results	57
6.1	Probability Assessment.....	57
6.2	Risk Assessment.....	58
	Bibliography	59

1 List of Abbreviations

3GPP	3rd Generation Partnership Project
A-BGF	Access Border Gateway Function
AGCF	Access Gateway Control Function
AGW	Access Gateway
AKA	Authentication and Key Agreement
AS	Application Server
A-SBC	Access Session Border Controller
BGCF	Breakout Gateway Control Function
CDF	Charging Data Function
CDR	Call Detail Records
CDR	Charging Data Records
CGF	Charging Gateway Function
DEA	Diameter Edge Agent
DRA	Diameter Routing Agent
HSS	Home Subscriber Server
I-CSCF	Interrogating Call Session Control Function
IMS	IP Multimedia Subsystem
I-PUPS	Inter-PLMN User Plane Security
I-SBC	Interconnect Session Border Controller
ISDN	Integrated Services Digital Network
MGCF	Media Gateway Control Function
MGW	Media Gateway
MME	Mobility Management Entity
MNO	Mobile Network Operators
MRF	Media Resource Function
P-CSCF	Proxy Call Session Control Function
PGW	Packet Data Network Gateway
PGW-C	Packet Data Network Gateway Control Plane
PGW-U	Packet Data Network Gateway User Plane
POTS	Plain Old Telephony Service
PSAP	Public-Safety Answering Point
PSTN	Public Switched Telephone Network
RAN	Radio Access Network
S-CSCF	Server-Call Session Control Function

SEPP	Security Edge Protection Proxy
SGW	Serving Gateway
SGW-C	Control Plane Serving Gateway
SGW-U	User Plane Serving Gateway
SIP	Session Initiation Protocol
TISPAN	Telecommunication and Internet converged Services and Protocols for Advanced Networking
UDM	Unified Data Management
UPF	User Plane Function
VoIP	Voice over IP

2 Introduction and Purpose

2.1 Intention

The intention of the document is to dive deep into the analysis of risk scenarios where the **IP Multimedia Subsystem (IMS)** or the **Interconnect layer** is the attacked or failing subsystem of a 5G network.

This document shows the current view on the probability that any risk scenarios could become reality.

The study is only available in English language, as the target group is primarily the international IT security community. The study is also in the context of English publications on this topic.

2.2 Link to Framework Document

This document is linked to the framework document and provides relevant information about the IMS and Interconnect technology and a probability assessment of relevant risk scenarios described in the framework document. The overall risk assessment for each risk scenario consists of the results of this analysis and the impact described in the framework document. The overall risk assessment for the IMS and Interconnect subsystem is summarized in Chapter 6.2 of this document and in the framework document.

3 Methodology

The methodology used for the 5G Risk Analysis (5G-RA) is based on PASTA. In this document and the related documents, we will refer to the methodology as 5G-RA.

This chapter explains the seven steps of the 5G-RA methodology and assigns them to the corresponding PASTA steps.

Step 1: Definition of Risk Scenarios

In the first step of the 5G-TARA, the 5G network needs to be analysed from the following three perspectives:

1. Public Mobile Network Operator (MNO) Perspective,
2. Private 5G Network Operator Perspective,
3. User Perspective.

Several risks with a significant impact on the society or public safety have been identified by the legislative in the past. To mitigate these risks, laws were set into force, e.g. the legislative to ensure emergency calls are available (TKG §165). Most of these laws define fines for mobile network operators if the regulative obligation is not followed.

These perspectives are explained in detail in Chapter 6 of the framework document. The goal is to identify the possible risks that the 5G network might be exposed to from each perspective.

Step 2: 5G System Diagram

In step 2, a detailed system diagram of the parts of a 5G network needs to be created. This diagram will serve as a basis for the following steps.

Step 3: Refinement of Detailed 5G Subsystem Diagrams

In this step, more technical definitions and explanations of the relevant 5G subsystems are introduced. For example, various network functions are part of the 5G core network. This level of detail serves as a basis for the following steps.

Step 4: Collection of Known 5G Threats

In this step, publicly known 5G specific threats are collected. For this purpose, relevant studies and input documents are collected. This is the basis for the identification of threats in the next step.

Step 5: Search of 5G Vulnerabilities

Step 5 includes the analysis and identification of relevant threats for each risk scenario. The findings of this step are part of the corresponding Detailed Risk Analyses.

Step 6: Examination of Identified Threats

In this step, all threats that were found in step 5 are examined on whether there is a possibility for this threat to be realized. Hypothetical scenarios are used as well as references to successful attacks, which were performed in the past.

Step 7: Risk Calculation

The last step of the methodology is a calculation of the risk for all threats that were identified in step 5 and are still considered relevant after step 6 was carried out. The overall results are presented in Chapter 6 of this document.

The following table assigns the steps of the 5G-RA to the steps of PASTA and gives an overview of the document containing the results of each step.

Table 1: Assignment of 5G-RA steps to PASTA-steps

#	5G-RA methodology	Document Layer	PASTA
1	Definition of Risk Scenarios	Framework	Define Objectives
2	5G System Diagram	Framework	Define Technical Scope
3	Refinement of Detailed 5G Subsystem Diagrams	Framework & Detailed Risk Analysis	Application Decomposition
4	Collection of Known 5G Threats	Detailed Risk Analysis	Threat Analysis
5	Search of 5G Vulnerabilities	Detailed Risk Analysis	Vulnerability and Weakness Analysis
6	Examination of the Identified Threats	Detailed Risk Analysis	Attack Modelling
7	Risk Calculation	Framework & Detailed Risk Analysis	Risk and Impact Analysis

4 5G Network Model: IMS and Interconnect

The 5G network model introduced in the framework document is used to split the 5G risk analysis into multiple Detailed Risk Analyses. The network model follows standards (like 3GPP standards) as much as possible and comprises a variety of interconnected subsystems that are categorized on a high-level view as shown in Figure 1. 5G networks may consist of any combination of 5G Standalone and 5G Non-Standalone architecture options, which therefore includes also 4G RAN (E-UTRAN) and 4G-CORE (EPC). However, this risk analysis covers only 5GC for the core. All other subsystems are not limited to 5G.

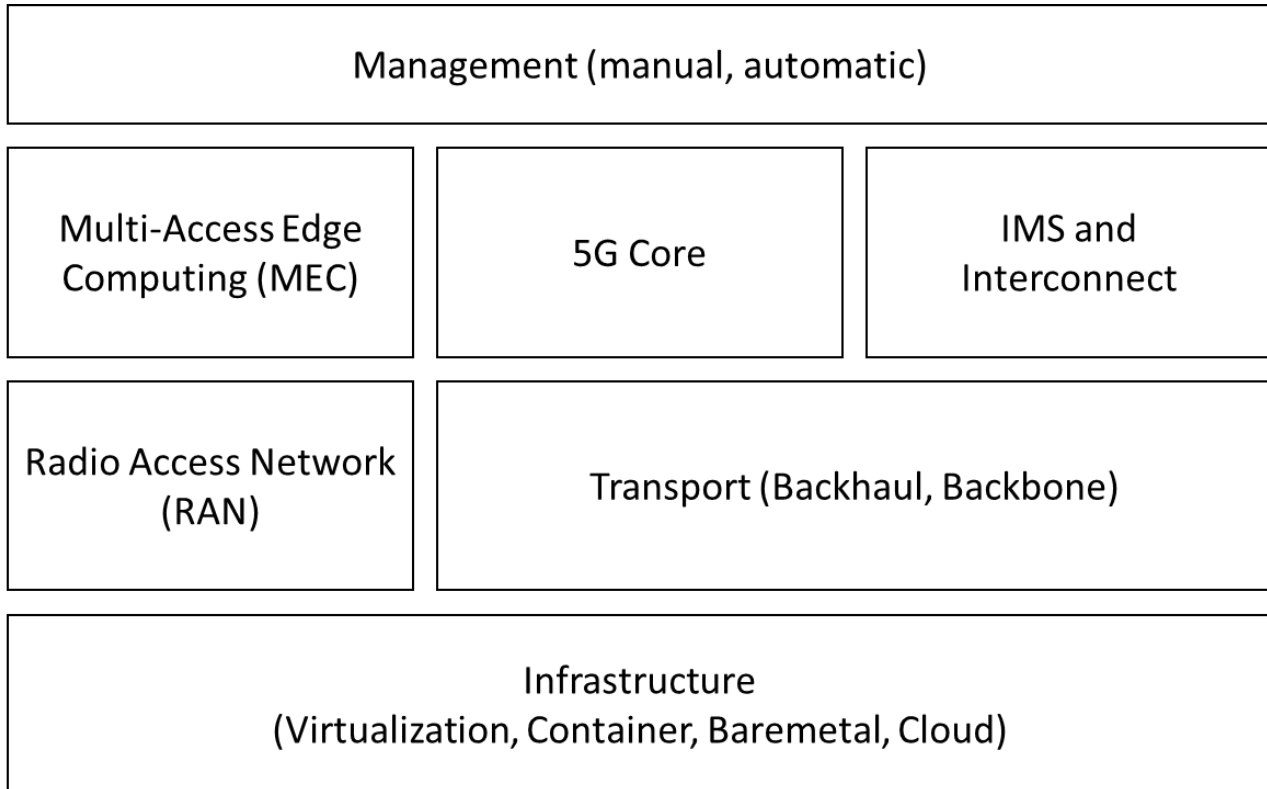


Figure 1: 5G Network Model: High level view

Other subsystems are not specifically designed for the 5G architecture and used either to operate the 5G system or to connect it to other internal and external networks.

4.1 IP Multimedia Subsystem (IMS)

The IP Multimedia Subsystem or IP Multimedia Core Network Subsystem (IMS) is a standardized architectural framework for delivering IP multimedia services. Historically, mobile phones have provided voice call services over a circuit-switched-style network, rather than strictly over a packet-switched system. Alternative methods of delivering voice, such as Voice over IP (VoIP), or other multimedia services have become available on smartphones, but they have not become standardized across the industry. IMS is an architectural framework that provides such standardization.

According to the 3GPP, IMS is not intended to standardize applications, but rather to aid the access of multimedia and voice applications from wireless and wireline terminals, i.e. to create a form of fixed-mobile convergence. This is done by having a horizontal control layer that isolates the access network from the service layer. Each individual service (e.g., voice telephony, video, IPTV, etc.) is built on top as an application.

IMS comprises several SIP proxies, media gateways, interconnection-specific nodes, and many other purpose-built components. To connect these components, IMS uses IETF protocols wherever possible, e.g. Diameter or the Session Initiation Protocol (SIP).

For the sake of simplicity and essential functionality, the focus of the risk analysis will be the SIP proxies, the subscriber and charging repositories, and breakout media gateways as described in detail below.

IP Multimedia Subsystem

System Diagram

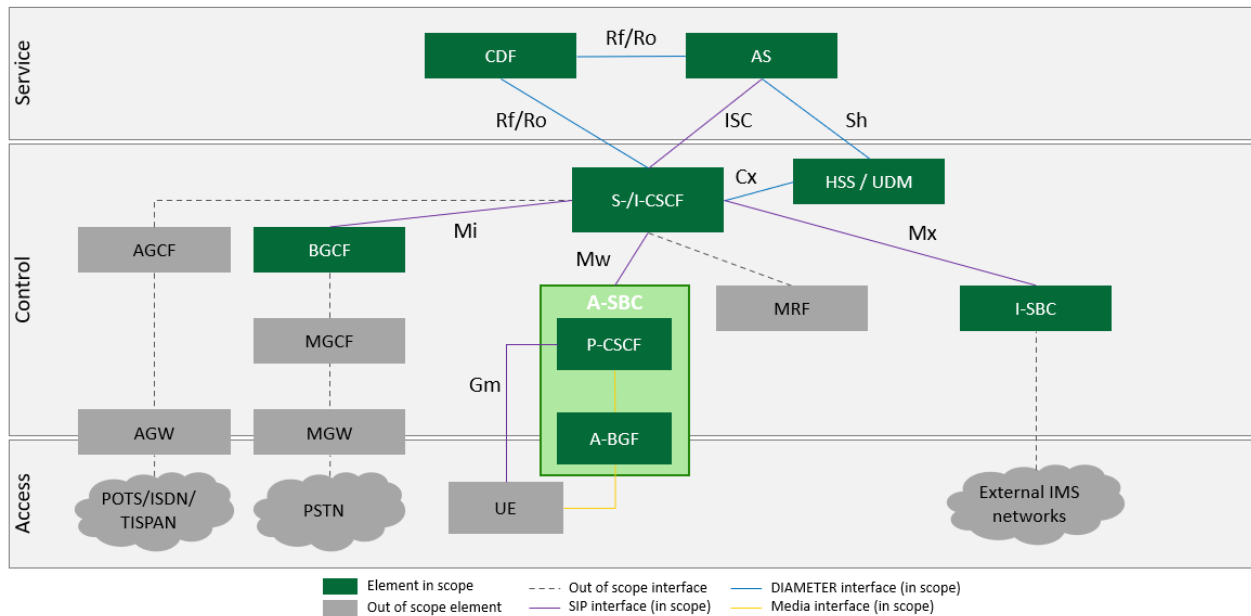


Figure 2: IP Multimedia Subsystem - System Diagram

4.1.1 Proxy Call Session Control Function (P-CSCF)

The Proxy-Call Session Control Function is the first point of contact in the IP Multimedia Subsystem architecture and is often placed at the network perimeter to function as an Access Session Border Controller (A-SBC) together with the Access Border Gateway Function, as illustrated in Figure 2. P-CSCF at its core is a SIP server that handles incoming SIP messages from the UE and is also the exit point for outgoing SIP messages toward the UE. Beyond that, its functionality also includes:

- Maintaining IPsec security associations with connected UEs
- Updating information about UEs' access network type and location
- Generating and providing charging information to the CDF

4.1.2 Interrogating Call Session Control Function (I-CSCF)

The Interrogator-Call Session Control Function, as the name suggests, is also a SIP trunk that sits in the middle and functions as a mediator between the P-CSCF and its corresponding S-CSCF. The I-CSCF takes care of user authorization via User Authorization Requests with the HSS and selects the proper Serving-CSCF that is closest to the UE. The S-CSCF selection criteria can be set either statically or dynamically through I-CSCF or set by HSS in UE profile.

4.1.3 Serving Call Session Control Function (S-CSCF)

The Serving-Call Session Control Function is the SIP server that handles the UE's signaling requests and is typically placed close to the UE. The S-CSCF handles the UE's authentication. Once the authentication is successful, it maintains the session state and handles SIP messages exchanged between the UE and different IMS nodes. This includes, among others:

- Routing SIP requests to their appropriate destination
- Facilitating services authorization with the help of the HSS/UDM; and
- Generating and providing charging information to the CDF

4.1.4 Access Border Gateway Function (A-BGF)

The Access Border Gateway Function (A-BGF) acts as a conduit between access and core networks, shielding the service provider's network during UE's access to packet-based services like IMS. It manages traffic, performs network address and port translation, and compiles usage information.

4.1.5 Interconnect Session Border Controller (I-SBC)

The Interconnect Session Border Controller (I-SBC) is deployed at the perimeter of the IMS domain, managing interconnect traffic exchanged with other SIP or IMS networks. This includes both Control Plane traffic and User Plane traffic. Given its location in the IMS network, it may also facilitate interoperability with other network domains, policy enforcement, and implement network security controls (e.g., topology hiding).

4.1.6 Home Subscriber Server (HSS)/Unified Data Management (UDM)

Home Subscriber Server (HSS)/Unified Data Management (UDM) is the main subscriber database, that contains the data for each user's profile. The HSS/UDM also supports generation of Authentication and Key Agreement (AKA) credentials, user identification handling and access authorization.

4.1.7 Application Server (AS)

IMS is designed to be modular and extensible. As such, its specifications do not define the internal architecture of the AS. Application servers can be used to provide different services – one of the most common and widely deployed being voice telephony (using a telephony application server/TAS).

4.1.8 Charging Data Function (CDF)

CDF supports service charging within the IMS infrastructure, ensuring that consumed services can eventually be billed to subscribers. To do so, it processes charging triggers by other IMS functions (e.g., CSCFs and AS) and creates Charging Data Records (CDRs). CDRs are forwarded to the Charging Gateway Function (CGF) before being processed by further billing systems.

4.1.9 Breakout Gateway Control Function (BGCF)

The Breakout Gateway Control Function (BGCF) is a pivot in an operator's network, set based on local configuration. It deals with routing requests and chooses the next step in SIP routing. This function pinpoints network selection for PSTN/CS Domain interaction, selecting a Media Gateway Control Function (MGCF) where needed. It propagates signaling between networks, forwarding messages to an Interrogating-CSCF (I-CSCF) in another IMS network or other IP destinations. It also generates Call Detail Records (CDRs).

4.1.10 Interfaces and reference points

4.1.10.1 Diameter-Protocol based interfaces:

Cx: Cx is a diameter-protocol based interface between the HSS/UDM and the I/S-CSCF. It is included as an exemplary interface between 5G Core and IMS. Considering the existing legacy deployment base, this diameter-based integration is expected to be more common in real-world deployments than the newer, service-based interfaces.

The main functionality of the Cx interface is the transfer of authentication and authorization credentials between the subscriber database and the SIP trunks to facilitate the IMS registration process.

Sh: The Sh interface is defined in 3GPP in TS 29.329 as a diameter interface between an AS and HSS. The Sh interface facilitates the transfer of subscriber data enabling the AS to obtain important subscriber information for service management. Additionally, it enables the HSS to receive updates on subscriber status changes that are necessary for charging and billing purposes.

Rf/Ro: The Rf/Ro interface transfers policy messages for charging purposes. Specifically, Rf handles offline charging functions and Ro serves online charging functions.

4.1.10.2 Session Initiation Protocol based Interfaces

Mx: Mx is a SIP-protocol based interface that handles media conversion and codec translation. It is worth mentioning that Mx interface is not typically part of the base IMS architecture as defined by 3GPP and primarily relevant for the support of legacy networks and functions within a next-generation network context.

Mi: The Mi interface is located between I/S-CSCF and media gateways, used to synchronize user sessions and toggle between proxy gateways when the P-CSCF changes due to subscriber mobility or coverage change.

Mw: The Mw interface facilitates messages between different CSCF instances. For example, when a subscriber initiates a SIP session, the Mw interface is used to transfer the signaling message from the S-CSCF to the I-CSCF, which might require an inquiry with the HSS to obtain the details of the called party's S-CSCF, and then forward the initial SIP invite to the called party's S-CSCF.

ISC: The IP Session Control interface sits between the S-CSCF and the Application Server (AS). The application server executes the actual services that IMS provide like telephony, Push-to-Talk, Video calling, etc. ISC using SIP signaling facilitates the SIP communication and harmonizes the protocol structure for proper handling.

Gm: The Gm interface is connecting the subscriber device/User equipment (UE) to the S-CSCF. This is important for initiating, modifying, or terminating call sessions.

4.1.10.3 Real-time Transport Protocol (RTP) Interfaces

Media Interface: This User Plane interface exists between the A-BGF and the UE and utilizes the Real-time Transport Protocol (RTP) for transferring data packets (typically voice data) to and from the UE.

4.2 5G Interconnect Network

Interconnect between different mobile network domains is essential for providing several basic services. For instance, it allows subscribers of different networks to reach each other and lets them roam into foreign networks when abroad. As such, a lot of security-relevant information is exchanged over interconnect interfaces between Mobile Network Operators (MNO) that, unless properly protected, can cause significant damage to both the MNOs itself as well as the subscribers. That said, due to a lack of security by design in legacy protocols such as SS7 and Diameter, securing the interconnect remains an ongoing issue for MNOs until today. The present document is intentionally limited to the description of relevant 4G LTE and 5G network elements, as interworking between these domains is expected to persist for several years to come. The subsequent risk analysis focuses on 5G-to-5G interconnect only.

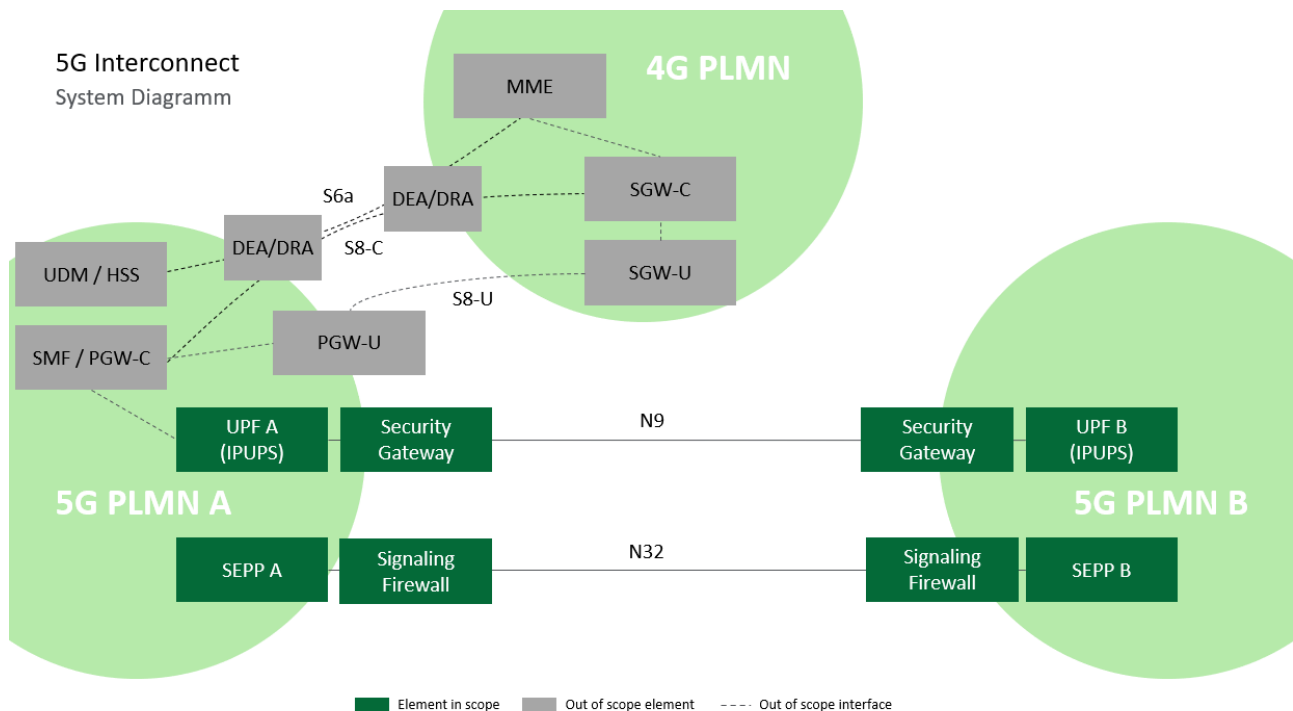


Figure 3: 5G Interconnect – System Diagramm

The 5G core network features two dedicated interfaces for interconnect with other 5G networks – N32 and N9. The N32 interface carries Control Plane (also called ‘signaling’) traffic for managing the interconnect communication. The N9 interface carries User Plane traffic, i.e. the information subscribers actually send and receive. The 3GPP technical specifications define two network elements, terminating these interfaces on either side: The Security Edge Protection Proxy (SEPP) handling Control Plane traffic, and the User Plane Function (UPF) handling User Plane traffic. In addition to these standard network elements, MNOs may decide to employ additional non-standard components which may provide additional functionality, for example, in terms of security.

Besides pure 5G-to-5G communication, the 5G network may also interwork with legacy 4G LTE networks. The scenario depicted in Figure 1 assumes a 5G home network and 4G LTE visited network. In this case, there are two signaling connections between both network domains: (1) between 4G Mobility Management Entity (MME) in the visited network and the UDM/HSS in the 5G home network, and (2) between the Control Plane Serving Gateway (SGW-C) and the Control Plane Packet Data Network Gateway (PGW-C). Both interfaces may feature a Diameter Edge Agent / Diameter Routing Agent (DEA/DRA) on either side of the communication. User Plane traffic is exchanged between the User Plane SGW (SGW-U) and the User Plane PGW (PGW-U). These above-mentioned elements and interfaces are described further in the following sections.

4.2.1 Security Edge Protection Proxy (SEPP)

The SEPP is a non-transparent proxy at the network perimeter handling signaling data exchanged with other mobile networks (via the N32 interface). It acts as the single point of contact for internal Network Functions (NF) and external roaming peers to directly interconnect signaling traffic to.

The SEPP's purpose is protecting both the mobile network itself as well as outgoing signaling traffic. Specifically, this includes (see [1]):

- Performing mutual authentication and negotiation of cipher suites with other SEPPs
- Handling key management, incl. cryptographic keys needed for securing N32 messages
- Protecting application layer control plane messages exchanged over the N32 interface
- Performing topology hiding, i.e., limiting internal network information visible externally
- Discarding malformed N32 messages
- Implementing rate-limiting functionality; and
- Implementing anti-spoofing mechanisms

4.2.2 Signaling Firewall

A Signaling Firewall may be used to provide additional protection on the N32 interface. An operator may decide to deploy such a network element to offload certain security checks from the SEPP to a dedicated network element, or because it offers additional, non-standard functionality (e.g., message correlation, heuristics-based checks, data analysis).

4.2.3 User Plane Function (UPF)

The UPF is a 5G Core NF that forwards User Plane traffic between the User Equipment (via the N3 interface) and either external data networks (via the N6 interface) or other mobile networks (via the N9 interface). In the context of 5G interconnect, communication via the N9 interface is the most relevant.

The UPF further includes the Inter-PLMN UP Security (IPUPS) functionality. Its purpose is enforcing GTP-U security on the N9 interface between UPFs of the visited and home network. Specifically, this includes (see also 3GPP TS 33.501 [1], section 5.9.3.4):

- Discarding GTP-U packets that are not associated to an active Protocol Data Unit (PDU) session; and
- Discarding malformed GTP-U messages

4.2.4 Serving Gateway (SGW)

The functionality of the SGW includes forwarding User Plane Data between UE and PGW, supporting handover procedures between 4G LTE radio nodes. Further, it stores context information about the UEs associated to it, for example, related to IP bearers. In interworking scenarios, the SGW also serves as the UE's anchor point forwarding traffic to other 3GPP networks. Depending on the deployment, the SGW may be split into a dedicated element handling User Plane data (SGW-U) and another one handling Control Plane data (SGW-C).

4.2.5 Packet Data Network Gateway (PGW)

The PDN Gateway's main functionality is forwarding User Plane traffic between the 4G LTE network and external data networks. Besides that, it also supports other functionality such as policy enforcement, charging, or lawful interception. Depending on the deployment, the PGW may be split into a dedicated element handling User Plane data (PGW-U) and another one handling Control Plane data (PGW-C).

4.2.6 Diameter Edge Agent / Diameter Routing Agent (DEA/DRA)

The DEA / DRA is a network element aimed at providing additional security on Diameter interfaces exposed externally. This may include message validation, filtering, and correlation to protect internal network functions from malicious traffic.

4.2.7 Interfaces and reference points

N32 (SEPP – SEPP)

The N32 interface carries Control Plane traffic between two SEPPs in different network domains, usually the visited and home network. Protection of data-in-transit on this interface may be provided in different ways, incl:

- Protection at the network layer using IPSec
- Protection at the transport layer using TLS; or
- Protection at the application layer using PRINS (Protocol for N32 Interconnect Security).

Multiple of these security protocols may be used together.

The N32 interface can be broken down further into N32-c and N32-f channel. The N32-c channel carries the Control Plane traffic for managing the SEPP-to-SEPP communication and is protected end-to-end via TLS. The N32-f channel carries the Control Plane traffic exchanged between different NFs in the visited and home network (i.e., the actual interconnect traffic). It may be protected via TLS or PRINS.

N9 (UPF – UPF)

The N9 interface carries User Plane traffic between two UPFs in different network domains, usually the visited and home network. Protection of data-in-transit on this interface is usually provided via IPsec ESP and IKEv2 certificate-based authentication. This protection may be applied by the UPF directly, or by a dedicated Security Gateway.

S6a (MME – HSS)

The S6a interface connects the MME with the HSS. It carries Control Plane traffic via the Diameter protocol and is essential, for instance, during the 4G LTE primary authentication procedure.

S8 (SGW – PGW)

The S8 interface connects the SGW and PGW in different 3GPP networks. It carries User Plane and Control Plane traffic via the GPRS Tunneling Protocol (GTP) and can be decomposed into S8-C (GTP-C) and S8-U (GTP-U).

4.3 Summary

Based on the above overview of system components and associated functionality, one can already identify the most sensitive components of the IMS and Interconnect 5G sub-systems, in the sense that they are essential for providing secure mobile services, and compromise or failure would most likely result in a direct breach of one or more essential security goals (i.e., Confidentiality, Integrity, Availability).

Within IMS, the most sensitive component by far is the subscriber database, i.e. HSS/UDM. It is commonly considered the crown jewel of a mobile network, as it stores subscriber profiles, permanent keys, and without it, customers would have no access to mobile services. In addition, one may also consider the Application Server a sensitive component, as it is the one implementing the business logic for the services consumed by subscribers (e.g. mobile telephony).

In the case of 5G Interconnect, there are no elements storing sensitive, service-critical information like in IMS. Instead, the main purpose of this sub-system can be summarized as securely enabling communication between different networks domains. As such, the most sensitive component here are those elements that are essential for mediating traffic between those domains and protecting the mobile network from malicious incoming traffic as well as outgoing traffic from threats on the interconnect network. Primarily, that includes the SEPP and the UPF/IPUPS. Other components, such as additional Security Firewalls or Gateways are an optional addition.

5 Risk Scenarios

This chapter provides the current view on a range of risk scenarios. It deals with an estimation of probabilities that each of this risk scenarios could become reality. These estimations are based on detailed discussions of potential scenarios of weaknesses or attacks. These discussions conclude with an assessment of the probability of occurrence.

The following table shows if the IMS and Interconnect network is a relevant subsystem of each risk scenario. The risk scenarios themselves are further described in the framework document.

This risk analysis focuses on technical risks and risk scenarios. Covering political aspects is out of scope. Not considered are risk scenarios related to the question, if the manufacturer of the equipment and the supply chain is trustworthy. On this topic exist various publications for IT systems in general [ENI]. A second risk not covered by this analysis is the not standard-conform implementation of components. This analysis assumes vendors comply with 3GPP and other standards as long as a standard for the functionality exists.

Perspective	Section	Risk Scenario	IMS/ Interconnect	CIA
Public MNO Perspective	5.2.1	Emergency Call (TKG § 164)	x	A
	5.2.2	Cell Broadcast (TKG § 164a)		A
	5.2.3	Telecommunications Secrecy (TTDSG § 3)	x	C
	5.2.4	Emergency Preparedness (TKG § 184)	x	A
	5.2.5	Regional Network Failure		A
	5.2.6	Multi-Regional Network Failure		A
	5.2.7	Failure of Mobile Service	x	A
	5.2.8	Fraud	x	I
	5.2.9	Subscriber-Data Leak	x	C
User Perspective	5.3.1	Urgent Telephone Calls Not Possible	x	A
	5.3.2	Authenticity of the Receiver of a Call	x	I
	5.3.3	Integrity of Transmitted Data	x	I
	5.3.4	User's Identity	x	C
	5.3.5	Eavesdropping of a Communication	x	C
	5.3.6	Slowing Down/Restricting the Connection	x	A
	5.3.7	Connection Failure	x	A
	5.3.8	Tapping or Altering of the Geographical Position	x	C
Private 5G Network Operator Perspective	5.4.1	Network Failure		A
	5.4.2	Degraded Services/Connections		A
	5.4.3	Information Disclosure		C
	5.4.4	User Identities (Authenticity/ Integrity)		I

5.1 Attack Paths and Risk Sources

For each risk scenario a couple of different attack paths and risk sources will be discussed within this document. The result of the discussion will be a probability level for the impact defined in the respective risk scenario.

An attack path refers to a sequence of steps or actions that an attacker can take to exploit vulnerabilities in a system or network, leading to security issues. It outlines the route or method an attacker follows to achieve his goals, often involving a series of interconnected actions that exploit weaknesses in a system's defences.

A risk source is defined as the origin or cause of a potential risk or threat. A risk source is identified as the factor or element that can lead to vulnerabilities or hazards.

As many of attack paths or sub-sequences of attack paths and risk sources are similar for most of the risk scenarios, each attack path and risk source will be introduced from the perspective of the IMS and Interconnect subsystem in this chapter.

In general, an attacker with legitimate access to MNO's assets that shall be protected is called internal attacker. An internal attacker could have access to physical or cryptographic keys, to buildings or rooms or to networks or systems.

5.1.1 Misconfiguration (AP1)

Misconfiguration as a possible attack path concerns all configurable parts of a system. A legitimate configuration can either be deployed by employees of the MNO or the manufacturer or by configuration tools. The cause of misconfiguration can be either human error thus happening unintentionally, or it can also be intentionally as part of an attack.

Misconfigurations may persist undetected if the impacted functionality was not used regularly or if configuration or security impacts of that functionality were not monitored.

5.1.1.1 Confidentiality (AP1-C)

Misconfiguration of 5G network components can cause a breach of confidentiality in several different ways. At a high level, one can distinguish between protecting the confidentiality of *data-in-transit* and *data-at-rest*. The former affects IMS and Interconnect subsystems equally, since both rely on similar network security protocols to encrypt data exchanged between network elements (i.e., IPsec and/or TLS). The latter is an issue primarily in the context of secrets management: Any network element that uses security protocols needs to be provisioned with and securely store cryptographic material, be it public-key certificates, API keys, or passwords. One network element that stands out in this regard is the subscriber database UDM/HSS, which stores not only cryptographic material for protecting its own communication, but also the primary keys and subscription profiles of end customers.

Data-in-transit

Insufficient protection of data-in-transit may be caused by different misconfiguration scenarios. One option is that an operator is not using network security protocols whatsoever, either not enabling them or failing to provision cryptographic material in the first place. Such a lack of cryptographic protection when transmitting information over the network exposes it to any malicious actors with access to the communication [2]. This is particularly crucial on interfaces over which authentication information, location data, and other sensitive information is transmitted. In the case of Interconnect, this includes the N32 interface. In the case of IMS, this includes Cx interface.

Even if network security protocols have been enabled, their ability to effectively protect the transported data-in-transit depends on the cryptographic algorithms they rely on. Both IPSec —used to protect IMS and Interconnect interfaces— and TLS —used to protect the N32 interface between SEPPs— can be profiled to use different authentication, encryption, and integrity algorithms. Selecting weak or vulnerable cryptographic profiles can render the protection ineffective [3].

For data exchanged over the N32 interface, another layer of protection in addition to IPSec or TLS is the 3GPP-defined application layer protocol PRINS. Confidentiality in PRINS is controlled by the ‘Data-type encryption policy’ capturing information elements in need of protection. Unless all relevant information elements are configured in this policy by the network operator, sensitive information may be exposed to unauthorized parties in the absence of additional protection at transport of network layer.

Data-at-rest

Protection of data-at-rest, both in the IMS and the Interconnect subsystems, can be threatened by a lack of system security hardening. Failure to minimize the attack surface of a system —for example, by means of disabling/removing unnecessary accounts or disabling/removing unneeded functionality— may allow internal and external malicious actors to gaining unauthorized access to it, thereby threatening data confidentiality, integrity, and system availability. Implementing appropriate configurational measures are especially important for network elements that are exposed to external parties, including SEPP, UPF, I-SBC, and DEA/DRA [4].

5.1.1.2 Integrity (AP1-I)

Data-in-transit

The integrity risks to data-in-transit due to a misconfiguration are very similar to those outlined in AP1-C. That is, a flawed configuration of network security protocols equally threatens data integrity.

In the case of PRINS, misconfigurations threatening data integrity can occur in the ‘Modification policy’ describing which information elements may be modified by authorized third parties on the interconnect network. This may be required, for example, for the translation of individual elements in the interest of maximum interoperability. However, if this policy is not restrictive enough, such third parties may be able to modify data that is not required to be updated.

Data-at-rest

Similar to AP1-C, minimizing the attack surface of network functions and other network elements is an important aspect of ensuring the integrity of data-at-rest.

5.1.1.3 Availability (AP1-A)

Misconfiguration of key network components also has the potential to impact network and service availability. One example is improper certificate management. In the context of interconnect communication, missing or improperly configured public-key certificates in I-SBC, SEPP, or IPUPS may lead to failures in communication with roaming partners. Moreover, misconfigured or expiring public-key certificates can also disrupt communication between other network elements within an operator’s internal network that rely on them for secure communication (e.g., between different CSCF).

In addition to certificate management, perimeter security elements —such as the SEPP, DEA/DRA, and Signalling Firewalls— bear further misconfiguration potential that may negatively impact availability. Overly restrictive filtering may lead to unintentional blocking of legitimate traffic, disrupting normal operations [5]. Conversely, a configuration that is too permissive can be exploited by attackers to inject malicious traffic, targeting internal network components [6].

5.1.2 Insufficient Access Controls (AP2)

Access control involves authentication and authorization, i.e., correctly verifying the identity of a subject (e.g., system users) and assigning them the appropriate permissions. If either of those steps does not function as intended, it may allow unauthorized access by malicious actors or prohibit legitimate access. A Common attack path is not deleting ex-employee credentials that might be exploited later [7]. Another example of this is using depreciated authentication algorithms resulting in weakening the authentication mechanism [8].

5.1.2.1 Confidentiality (AP2-C)

Insufficient authentication and authorization measures, including a lack of multi-factor authentication (MFA), present security risks for all network elements in the IMS and Interconnect subsystems. Both external and internal attackers may exploit vulnerabilities such as flawed authentication methods, weak credentials, or the lack of brute-force protection to gain unauthorized access to restricted data and services. This is especially critical for elements which hold sensitive or private information, such as the HSS/UDM [9].

5.1.2.2 Integrity (AP2-I)

A lack of spoofing protection may allow attackers to disguise fraudulent traffic as legitimate. This is particularly relevant on externally exposed interfaces, such as, the N32 and N9 Interconnect interfaces or the Ici and Izi IMS interfaces. By impersonating legitimate roaming partners and injecting malicious Control Plane or User Plane messages an attacker could potentially gain unauthorized access, cause fraudulent service charges, or even cause disruption of services [10].

5.1.2.3 Availability (AP2-A)

Availability may be a secondary damage once access control has been bypassed or otherwise breached by a malicious actor. Although, it is not usually a direct result of flawed access control, access control for any system supporting emergency services and other mission critical communication for which availability is a key concern should be setup as restrictive as possible to minimize the risk of service disruption.

IMS supporting these kinds of mission-critical communications must be designed with high availability in mind, and this starts with stringent access control policies. These policies should be as restrictive as possible, only providing access to authenticated and authorized entities and removing access rights as soon as they're not deemed necessary. This minimizes the risk of unauthorized individuals disrupting the services through malicious activities or accidental network changes.

5.1.3 Implementation Flaw (AP3)

Flawed implementations can give rise to a plethora of security vulnerabilities threatening confidentiality, integrity, and availability. While obvious mistakes can be mitigated through review and testing during the implementation stage easily, more involved issues are more likely to make it into the final product, particularly as the complexity of the overall product grows.

5.1.3.1 Confidentiality (AP3-C)

Any implementation, both of IMS and Interconnect network components, should avoid storing information in plain text and transferring it over the network unprotected, thereby exposing it to potentially malicious actors. This is particularly important for components that store sensitive data (e.g., HSS/UDM) and those communicating over external networks (e.g., SEPP, DEA/DRA, I-SBC).

Controls to prevent such blatant information exposure, e.g., network security protocols, can themselves also be subject to implementation issues. Protocol weaknesses may be exploited by attackers to downgrade, bypass, or completely disable essential security mechanisms [12].

Of course, no security protocol can ensure effective confidentiality protection if the cryptographic material used for it is not adequately protected. Therefore, implementing proper secrets management, is also essential for ensuring confidentiality [13].

Another risk to confidentiality that may be prevented at the implementation stage is the excessive exposure of restricted interfaces or services (e.g., management interfaces). This is especially relevant for those network functions and components that are by necessity exposed externally, including SEPP, DEA, I-SBC, and UPF. Unintended exposure at those points of the network presents a substantial risk and unauthorized access can lead not only to data breaches, but also service disruptions, and compromised network integrity [14].

5.1.3.2 Integrity (AP3-I)

One way in which the UPF/IPUPS aim to protect integrity is by filtering malformed input and correlating incoming packages on the N9 interface against currently active sessions. Inadequate validation and filtering at this point can pose a risk to network functions and components located behind the UPF. An attacker could exploit an implementation flaw to bypass the perimeter security and inject malicious traffic, ultimately undermining the overall network stability and security. Similar input validation and filtering functionality—and potential for implementation flaws—can also be found in the SEPP, DEA/DEA, and the I-SBC.

Flawed implementation can be particularly problematic when the low-level design of protocols and components is not done correctly. For example, the implementation of the SIP protocol entails many validations for the purposes of credit-control and user authorization. As such, poor protocol implementations can cause various issues related to data integrity [15].

5.1.3.3 Availability (AP3-A)

Intentional Denial of Service

Flaws in the traffic filtering and rate limiting functionality commonly implemented at the network perimeter can also threaten availability. An attacker can exploit such flaws in network components such as the SEPP, DEA/DRA, or the I-SBC to flood the network with excessive traffic. As a result, either those components themselves or internal network functions located behind them may suffer degradation or even a complete disruption of service [16] [17].

Unintentional Denial of Service

Denial of service situations may not only be the result of intentional attacks, but they may also happen by accident due to implementation failures. Unless robust network protocols and basic input validation are implemented by all network functions and elements across, it may lead to incompatibilities and message processing issues [18].

5.1.4 Specification Weakness (AP4)

Specification weaknesses can affect both IMS and Interconnect environments equally. Since industry specifications and standards —such as those developed by 3GPP— are primarily concerned with ensuring interoperability, their scope is often limited to determining the interactions and communication flows between functional elements, rather than the exact implementation of the elements themselves. As such, this is also where specification weaknesses tend to occur.

In addition to that, different standardisation bodies are involved such as the Internet Engineering Task Force (IETF) setting specifications for protocols, 3GPP2 (mostly concerned with CDMA2000) as well as regional regulatory bodies like the European Telecommunications Standards Institute (ETSI). Adding to the complication and lack of harmonization that the IMS suffers from [19].

5.1.4.1 Confidentiality (AP4-C)

A compromise of confidentiality may be caused by technical specifications relying on insecure network protocols, either due to vulnerable cryptographic algorithms, or due to the complete absence of basic security controls, such as mutual authentication of communication partners. In the realm of telecommunications, the legacy signalling protocol Signalling System 7 (SS7) is a prominent example for a network protocol designed without security in mind causing major security and fraud issues to this day [6].

In the context of 5G specifically, the 3GPP technical specifications also define mandatory security requirements to be met by 5G network components, covering not only communication security but also other fundamental security measures, for example, secure cryptographic key storage (see 3GPP TS 33.501 [1], chapter 5). For instance, section 5.9.3.3 specifies the protection of information elements by the SEPP when transferred via the N32 interface, incl. Authentication Vectors, cryptographic material, and subscriber location data. If sensitive information is left unspecified, it may result in a significant breach of confidentiality [2].

5.1.4.2 Integrity (AP4-I)

Similar considerations apply to the protection of integrity in the technical specifications as do for confidentiality (see AP4-C).

5.1.4.3 Availability (AP4-A)

Availability failures are not usually a direct result of specification weaknesses. While inadequate or lacking specification certain does not contribute to the goal of ensuring availability, other phases of the system lifecycle, e.g., design, implementation, and test, are much more important in that respect.

5.1.5 Failure of Power Supply (AP5)

Electric power is essential for any computer system to function. As such, it is up to the system operator to ensure a reliable and consistent supply of power to avoid compromising the integrity and availability of their deployment.

Generally, power outages primarily affect the availability of critical services and non-critical services rather than compromising the integrity of data being transmitted. Hence, such interruptions to power supply are unlikely to pose a significant threat to the confidentiality of data. This is because, amidst a power failure, while services may be interrupted, the data in transit does not get exposed or become accessible, and

therefore, the secrecy of the information is largely maintained. Nonetheless, it's worth noting that the repeated and unanticipated cessation of power could potentially lead to minor issues with the accurate transmission and receipt of data, though this is typically a lesser concern compared to service availability.

5.1.5.1 Confidentiality (AP5-C)

A breach of confidentiality is usually not a direct damage resulting from a failure of power supply. While it is certainly possible that confidentiality is also breached as part of a more complex incident (e.g., during recovering phase involving third-party service providers), the primary damage is expected in the "Availability" category.

5.1.5.2 Integrity (AP5-I)

A power supply failure may result in a compromise of data integrity. For instance, sudden loss of power may affect data-in-processing and may damage storage devices. However, modern database and file systems usually come with appropriate controls to prevent or minimize these issues (e.g., transactional processing, checksum confirmation). Hence, the primary damage is expected in the "Availability" category.

5.1.5.3 Availability (AP5-A)

A failure of power supply has the most potential to directly result in a compromise of availability – be it at a limited scale, resulting in a degradation of service quality, or large scale, potentially resulting in a complete unavailability of service. The reasons for potential failures of power supply are manifold, including unintentional events, such as power outages, natural disasters, or hardware/software defects, but also intentional acts of sabotage.

Power interruptions might cause global outage when central nodes have lost power (Central IMS nodes, IP core routers or PS nodes that serve the IMS network) or regional service disruptions when power impacts proxy trunks that serve certain geographic area or its underlying IP and Transmission infrastructure. Both scenarios can cause telephony, messaging and other media services disruption but most importantly can also cause emergency service outages hindering emergency services abilities to respond to incidents in time or prevent critical evacuation notifications from being delivered to civilians [20].

5.1.6 Failure of Hardware Components or Unavailability of Spare Parts (AP6)

Although certain hardware components (e.g., persistent storage) have become reliable over the years, there is still potential for failures at the physical layer to impact system integrity and availability. It is therefore up to system designers, implementors, and operators, to build the system in such a way that isolated failures can be identified and rectified early on before impacting the service layer.

5.1.6.1 Confidentiality (AP6-C)

A breach of confidentiality is usually not a direct damage resulting from a failure of hardware components. While it is certainly possible that confidentiality is also breached as part of a more complex incident (e.g., during recovering phase involving third-party service providers), the primary damage is expected in the "Availability" category.

Another culprit is the improper handling of damaged hardware components, such as storage devices, that could potentially lead to breaches in data confidentiality. For example, if a failed hard drive containing sensitive information is not destroyed properly, that data could be recovered and exploited [21].

5.1.6.2 Integrity (AP6-I)

A failure of hardware components may result in a compromise of data integrity. Depending on which system component is affected, it could affect data-in-processing (e.g., due to a CPU or GPU failure), data-in-transit (e.g., due to a damaged network cable), and data-at-rest (e.g., due to bit rot). However, many of these low-level failure scenarios are likely to be mitigated by adequate security controls. For instance, storage drives commonly collect usage data (incl. error statistics) over the course of their lifetime and can be tested for bad sectors, network protocols implement error detection and recovery functionality to address unreliable channels. Therefore, the primary damage is expected in the “Availability” category.

5.1.6.3 Availability (AP6-A)

A failure of hardware components has the most potential to directly result in a compromise of availability – be it at a limited scale, resulting in a degradation of service quality, or large scale, potentially resulting in a complete unavailability of service. The reasons for potential failures of hardware components include unintentional events, such as electric spikes or surges, environmental factors such as moisture or temperature, or hardware/software defects, but also intentional acts of sabotage [22].

5.1.7 Design & Architecture Flaws (AP7)

Although informed by technical specifications, the system design & architecture of telecom networks is still defined by the network operator to a large extent. At this stage, too, pitfalls exist that can impact the security of the overall deployment.

5.1.7.1 Confidentiality (AP7-C)

While the system diagrams in chapter 4 assume the presence of dedicated security components at the network perimeter such as SEPP and DEA/DRA it is important to recognize that it is up to the network operator whether to deploy them or not. Technically, communication can also happen without them. But of course, this exposes the network to significant risk from incoming malicious traffic and exposure of internal services and information to unauthorized parties [6].

5.1.7.2 Integrity (AP7-I)

Similar risks due to the lack of appropriate security components as outlined in AP7-C also apply for integrity. On Interconnect interfaces carrying Control Plane traffic, this is particularly critical, as a lack of protection may open the door to malicious actors targeting subscribers, incurring fraudulent charges, or compromising internal network elements [6].

5.1.7.3 Availability (AP7-A)

Network architecture and design plays a key role in ensuring service availability and reliability. For example, a lack of redundancy may create single points of failure that threaten to disrupt subscriber services in the event of an incident, e.g., relying on a single SEPP instance to serve the entire network. Similarly, failure to implement multi-layer security can allow attackers to easily expand their attack and affect the stability of the overall network once the first layer of security controls has been bypassed or broken.

Another prominent example is a lack of geographical distribution of S-CSCFs or poor S-CSC selection criteria both of which might impact the availability and quality of the media and voice transmission [23].

5.2 Public Mobile Network Operator (MNO) Perspective

This section discusses the risk scenarios related to the MNOs perspective.

For each subsection following, a short evaluation of the relevance of the risk scenarios in the IMS and Interconnect subsystem is discussed and the probability that potential attack paths could be exploited is derived.

5.2.1 Emergency Call (TKG § 164)

Emergency calls are a use case of voice telephony services provided by the IP Multimedia Subsystem. Since they connect subscribers to local emergency responders and other mission critical services, they are usually handled by the serving network operator. As such, the Interconnect subsystem is generally not involved in emergency calls. The network always connects the subscriber to the local emergency service, regardless of if it's a local or a roaming subscriber. Within the IMS domain, an attacker may try to compromise CSCFs handling call routing, thereby affecting service in a certain area of the network. More likely, however, malicious actors would be more interested in central IMS components, such as UDM/HSS and AS, both of which are essential for emergency calls. The subscriber database UDM/HSS may be involved during primary authentication in jurisdictions where emergency calls must be authenticated. The (Telephony) Application Server is the network component actually implementing the business logic for voice telephony services. For inbound roaming, the home network of the subscriber is involved authenticating and authorizing it to make phone calls on the visited network, a failure on the home network side of the subscriber can render the emergency call at the visited network unavailable.

Therefore, **IMS is considered** as a relevant attack domain for the risk scenario Emergency Call. Conversely, **Interconnect is not considered**.

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Misconfiguration	Availability (AP1-A)	Misconfiguration of IMS elements may lead to degradation in service quality or even unavailability of mission critical voice service, such as emergency calls. This includes SIP routing functions such as, P-CSCFs, S-CSCFs, BCGFs, and other network components in the path forwarding the emergency call from the local IMS domain towards a designated Public-Safety Answering Point (PSAP). Situations where misconfigurations can occur are numerous, incl. regular maintenance and rollout of new hardware which have led to issues with emergency services availability in the past [24] [25]. Therefore, the probability of these incidents is considered MEDIUM .	Medium

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Insufficient Access Controls	Availability (AP2-A)	The risk of insufficient access control to IMS components forwarding emergency calls is the same as for any other parts of the network. Although it is not usually a direct result of flawed access control, access control for any system supporting emergency services and other mission critical communication for which availability is a key concern should be setup as restrictive as possible to minimize the risk of service disruption. Considering that the relevant IMS components are deployed in a central location of the network with few stakeholders having direct access to them, the probability of these incidents is considered LOW .	Low
Implementation Flaw (Quality of the Product)	Availability (AP3-A)	Implementation flaws can occur at multiple points between UE and PSAP (RAN, 5G Core, IMS, etc.). However, it is unlikely that critical flaws threatening the availability of emergency calls would go unnoticed by the vendors' and MNO's testing processes or apply solely to emergency call scenarios. Therefore, the probability of these incidents is considered LOW .	Low
Specification Weakness	Availability (AP4-A)	Availability failures are generally not a direct result of a specification weakness as the specifications are constantly discussed and improved and because 3GPP specifications grant great freedom of implementation to individual vendors, making a service failure more implementation and design related. For ensuring service availability, network design, implementation, and tests are much more relevant than specification weakness (see also "Design and architecture flaws" below). Therefore, the probability of these incidents is considered LOW .	Low
Failure of Power Supply	Availability (AP5-A)	Failure of power supply affecting IMS components can impact the availability of different services, including emergency calls. For example, unavailability of a CSCF handling SIP session from subscribers in a certain area would likely also affect their ability to make emergency calls. The reason of power outages may include unintentional defects [26], intentional sabotage, external issues at the power grid operator, or environmental conditions. Although public MNOs are expected to have adequate controls in place to prevent these incidents from happening (e.g., redundant access to power grids, uninterruptable power supplies, generators), not all aspects of the power supply are under the control of the MNO itself, and the numerous real-world examples of power failures leading to data center outages exemplifies that the risk is present [20]. Given all the measures MNO typically take to prevent data center-wide power outage, the probability of these incidents is considered MEDIUM .	Medium

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Failure of Hardware Components or Unavailability of Spare Parts	Availability (AP6-A)	Failure of hardware components associated to central IMS elements can impact the availability of emergency calls. However, it is expected that public MNOs would generally have redundancy and recovery capacity at the infrastructure level in place to prevent isolated hardware failures from impacting the service layer – especially for mission critical services (see also “Design and architecture flaws” below). Therefore, the probability of these incidents is considered LOW .	Low
Design and architecture flaws	Availability (AP7-A)	Various design decisions in the IMS subsystem can affect the availability/resiliency of voice services, incl. emergency calls. This includes the deployment location of relevant IMS elements (P-CSCFs, S-CSCFs, etc.). Ideally, they should be distributed across the service area, so that a regional incident does not affect all critical components at once, possibly impairing emergency call quality/availability. It is assumed that public MNOs take these considerations into account during their deployment planning and, in the event of a local availability issue, have the ability to compensate by adequate recovery sites and the ability to switch over. Therefore, the probability of these incidents is considered LOW .	Low

5.2.2 Cell Broadcast (TKG § 164a)

Cell Broadcast Services (CBS) are provided by the 5G Core and rely on the RAN to reach an operator’s subscribers. They are generally provided by the serving network operator and do not involve the Interconnect and IMS subsystems.

Unlike Short Message Service (SMS) over IP that is routed through the IMS, cell broadcast messages are delivered directly by Core and RAN and do not require the involvement of the IMS network.

Therefore, **IMS and Interconnect subsystems are not considered** as relevant attack domains for Cell Broadcast Services.

5.2.3 Telecommunications Secrecy (TTDSG § 3)

Telecommunication Secrecy requires subscriber’s communication contents and associated metadata to be kept confidential. Both IMS and Interconnect are subdomains of the 5G System which handle subscriber related data. As such, there exists a potential for it to be breached and, intentionally or unintentionally, exposed to third parties.

Therefore, **IMS and Interconnect subsystems are considered** as relevant attack domains for the risk scenario Telecommunication Secrecy.

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Misconfiguration	Confidentiality (AP1-C)	Both IMS and Interconnect subsystems handle User Plane data of subscribers which –unless properly protected– may result in a breach of telecommunication secrecy. On one hand, data-in-transit may be exposed to unauthorized parties within the public MNO on internal media interfaces. On the other hand, there is a risk of exposing such data to external parties on interconnect links, such as N9, and between I-SBC instances in different network domains. The probability of these incidents is considered High. Although public network operators should have sufficiently mature testing and change management processes in place to prevent such breaches of confidentiality, there is still a HIGH likelihood of issues to occur, e.g., as a result of regular maintenance.	High
Insufficient Access Controls	Confidentiality (AP2-C)	Insufficient access control may expose subscribers' communication contents and associated metadata at any network function that handles User Plane traffic, incl. UPF, A-SBC, and I-SBC. Considering these network elements are situated at the network perimeter, they are highly exposed to malicious actors, though public MNOs are expected to have sufficiently mature operational practices in place to ensure access to them is adequately restricted. Nevertheless, there are real-world examples of MNO systems being compromised due to insufficient access control, revealing sensitive communication records: Not just the network functions themselves, also the platforms hosting them are a potential target for attackers and a compromise can lead to a breach of telecommunications secrecy [27]. Therefore, the probability of these incidents is considered HIGH .	High
Implementation Flaw (Quality of the Product)	Confidentiality (AP3-C)	Implementation flaws related to cryptographic security protocols (e.g., IPSec, TLS) protecting data-in-transit on User Plane interfaces, such as N9, have the potential to impact telecommunication secrecy. Abusing insecure implementations, attackers may be able to access communication contents. In addition, implementation issues with the relevant Network Functions themselves may additionally pose a risk as well. Although grave issues threatening the confidentiality of User Plane traffic should be caught by vendor's and the MNO's testing processes, there is still a chance for such issues to go unnoticed. Therefore, the probability of these incidents is considered MEDIUM .	Medium

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Specification Weakness	Confidentiality (AP4-C)	Parts of the specification detailing the protection of <i>data-at-rest</i> and <i>data-in-transit</i> may threaten telecommunication secrecy as User Plane traffic is processed by the standard IMS / Interconnect elements (e.g., UPF, A-SBC, I-SBC) and transferred over standard interfaces (e.g., N9, IMS media interfaces). For example, an obvious mistake would be the use of weak or vulnerable cryptographic algorithms. However, considering the specification and review process that involves numerous industry stakeholders and, at times, even public review, an error occurring at this stage is rather unlikely. Weaknesses related to non-standard components and interfaces (e.g., management tools, monitoring agents) are considered more likely. Given that their security is entirely up to the individual vendor, design and implementation issues may occur more often at those points. One may consider this an issue caused by <i>underspecification</i> , i.e., the technical specifications not prescribing enough security measures. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Failure of Power Supply	Confidentiality (AP5-C)	A breach of confidentiality is usually not a direct damage resulting from a power supply failure. While it is certainly possible that confidentiality is also breached as part of a more complex incident (e.g., during recovering phase involving third-party service providers), the primary damage is expected in the “Availability” category. Therefore, the probability of these incidents is considered LOW .	Low
Failure of Hardware Components or Unavailability of Spare Parts	Confidentiality (AP6-C)	A breach of confidentiality is usually not a direct damage resulting from a damaged hardware. While it is certainly possible that confidentiality is also breached as part of a more complex incident (e.g., during recovering phase involving third-party service providers), the primary damage is expected in the “Availability” category. Therefore, the probability of these incidents is considered LOW .	Low
Design and architecture flaws	Confidentiality (AP7-C)	A failure of telecommunication secrecy may also be the result of a network design/architecture failure leading to insufficient confidentiality protection of user related data. For example, if important but optional security controls are omitted (e.g., physical security gateways providing protection at the network layer) attackers may be able to access communication contents. However, it is expected that such blatant design flaws would be prevented by a public MNO's security review processes. Therefore, the probability of these incidents is considered LOW .	Low

5.2.4 Emergency Preparedness (TKG § 184)

Public mobile network operators in Germany are required by law to ensure availability of their communication services in the event of a disaster (e.g., a natural catastrophe). This includes voice and data services, internet access, and e-mail services. Roaming services on the other hand are not specifically mentioned in TKG § 184.

Therefore, **IMS is considered** as a relevant attack domain for emergency call services. Conversely, **Interconnect is not considered**.

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Misconfiguration	Availability (AP1-A)	If IMS nodes are not properly configured or incorrectly set up, they might be unable to correctly route emergency service calls. This could potentially cause a delay in emergency response or failure in delivering the service promptly. An example of this is: If the Operator Determined Barring (ODB) is mishandled on all or certain subscribers or by improperly classifying Traffic (Wrong QCI/5QI) that leads to failure of prioritizing emergency traffic. Considering the complexity of IMS deployments and the numerous occasions during which a misconfiguration can occur (e.g., regular maintenance, introduction of new components), the probability of these incidents is considered HIGH .	High
Insufficient Access Controls	Availability (AP2-A)	The risk of insufficient access control to IMS components impacting emergency preparedness is the same as for any other parts of the network. Although it is not usually a direct result of flawed access control, access control for any system supporting emergency services and other mission critical communication for which availability is a key concern should be setup as restrictive as possible to minimize the risk of service disruption and as a result negatively impacting the emergency preparedness of the network. Considering that the relevant IMS components are deployed in a central location of the network with few stakeholders having direct access to them, and general data center remote access protection, the probability of these incidents is considered LOW .	Low
Implementation Flaw (Quality of the Product)	Availability (AP3-A)	Correct technology implementations are crucial for ensuring the network is resilient and redundant enough to handle emergency services in unusual network circumstances like regional high-traffic spikes. An important metric is how many Diameter transactions per second (TPS) it can handle before introducing delay or call failure. Another example is if the IMS traffic gateways cannot correctly interpret and enforce Quality of Service (QoS) policies, the voice traffic for emergency calls might not receive the necessary priority, leading to possible delays or dropped calls in busy network conditions. Although testing processes at the IMS vendor and the operators should identify the most severe flaws, real-world scenarios of prioritizing emergency traffic are critical albeit difficult to simulate and test with similar emergency circumstances, so testing cannot guarantee the absence of implementation issues. Therefore, the probability of these incidents is considered MEDIUM .	Medium

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Specification Weakness	Availability (AP4-A)	Availability failures are generally not a direct result of a specification weakness. For ensuring availability, design, implementation, and test are much more relevant (see also “Design and architecture flaws” below). Therefore, the probability of these incidents is considered LOW .	Low
Failure of Power Supply	Availability (AP5-A)	Keeping emergency services running during a power outage is challenging when the outage occurs at data centers that host a centrally used IMS service. However, this would usually be mitigated by alternative power sources supplying needed power to critical parts of the data center and other redundant components to ensure high availability of critical infrastructure. Therefore, the probability of these incidents is considered LOW .	Low
Failure of Hardware Components or Unavailability of Spare Parts	Availability (AP6-A)	Similar to the failure of power supply, the IMS deployment has to bear redundancy in mind not only on the IMS components but also on the networking and transmission infrastructure underneath it [28]. Direct IMS nodes failure however is rather unlikely or quickly mitigated due to the potential that such a failure leads to a global outage (failure of entire network and not a region or segment). Therefore, the probability of these incidents is considered LOW .	Low
Design and architecture flaws	Availability (AP7-A)	Various design decisions in the IMS subsystem can affect the availability/resiliency of voice services, incl. emergency calls. This includes the deployment location of relevant IMS elements (P-CSCFs, S-CSCFs, etc.). Ideally, they should be distributed across the service area, so that a regional incident does not affect all critical components at once, possibly impairing emergency call quality/availability. It is assumed that public MNOs take these considerations into account during their deployment planning and, in the event of a local availability issue, have the ability to compensate by adequate recovery sites and the ability to switch over. Therefore, the probability of these incidents is considered LOW .	Low

5.2.5 Regional Network Failure

Regional Network Failure describes a network unavailability limited to a relatively small geographical area. Since the network functions associated to the IMS and Interconnect subsystems usually serve a larger service area (in contrast to failure of a singular base station, for example), this risk scenario is not applicable in this case.

Therefore, **the IMS and Interconnect subsystems are not considered** as relevant attack domains for the risk scenario Regional Network Failure.

5.2.6 Multi-Regional Network Failure

Multi-Regional Network Failure describes network unavailability in large parts of the service area. This is a more severe form of the Regional Network Failure, described in section 5.2.6. While IMS and Interconnect services are essential for providing certain communication services, such as voice telephony and roaming, a failure of either of them would not result in a complete unavailability of the entire network.

Therefore, **the IMS and Interconnect subsystems are not considered** as relevant attack domains for the risk scenario Multi-Regional Network Failure.

5.2.7 Failure of Mobile Service

Failure of Mobile Service describes a scenario in which specific communication services are unavailable in the entire coverage area, even though the user equipment is successfully registered and connected to the network. Considering the functionality of the IMS and Interconnect subsystems within the 5G System, a compromise of either can lead to such kind of incident. For example, a failure of IMS components, such as the Application Server, could inhibit voice telephony services, and an issue with interconnect functions like the SEPP would lead a failure of roaming service for all inbound and outbound roamers.

Therefore, **both IMS and Interconnect subsystems are considered** as relevant attack domains for the risk scenario Failure of Mobile Service.

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Misconfiguration	Availability (AP1-A)	Misconfiguration of the interconnect interface can affect inbound roamers across the network and outbound roamers in any foreign serving network. Misconfiguration of central IMS elements (e.g., PCF/PCRF, DRA, UDM/HSS, AS) may lead to service degradation across the entire network. However, some of these elements are less often reconfigured after initial reinauguration (ex. AS, P/I/S-CSCF and Media gateways), and public network operators should have proper maintenance processes in place to avoid configuration issues [29]. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Insufficient Access Controls	Availability (AP2-A)	For a failure of mobile service, malicious actors would need to abuse the access controls of central IMS/ Interconnect elements (e.g., UDM/HSS, AS, SEPP). Public network operators should have sufficient multi-layer security in place that would stop an external attacker from reaching this point. However, internal attackers may have an easier time abusing their privileges or get access to privileges they are not supposed to have. Therefore, the probability of these incidents is considered LOW .	Low

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Implementation Flaw (Quality of the Product)	Availability (AP3-A)	If a serious implementation flaw affects central IMS/ Interconnect elements (e.g., UDM/HSS, AS, SEPP), it can potentially affect availability of service in multiple regions, depending on the deployment. Generally, public network operators should have sufficient testing processes, redundancy, and multi-layer security for these components in place that would help them avoid such a situation. However, despite that there are examples of implementation flaws affecting the availability of large parts of public network deployments [30]. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Specification Weakness	Availability (AP4-A)	Availability failures are generally not a direct result of a specification weakness. For ensuring availability, design, implementation, and test are much more relevant (see also “Design and architecture flaws” below). Therefore, the probability of these incidents is considered LOW .	Low
Failure of Power Supply	Availability (AP5-A)	Complete interruption of service would only happen if core components were affected (e.g., UDM/HSS, SEPP, AS). However, it can be expected that those components would usually be deployed in a redundant fashion and operators have measures in place to compensate for temporary power supply failures (e.g., through alternative power sources, redundancy, or failover sites). Therefore, the probability of these incidents is considered MEDIUM .	Medium
Failure of Hardware Components or Unavailability of Spare Parts	Availability (AP6-A)	Complete interruption of service would only happen if core components were affected (e.g., UDM/HSS, SEPP, AS). However, it can be expected that those components would usually be deployed in a redundant fashion and operators have measures in place to compensate for isolated hardware failures. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Design and architecture flaws	Availability (AP7-A)	Lack of redundancy / failover potential for IMS and Interconnect elements is likely to result in a negative impact on availability. When IMS is positioned to aid the data network by activating bearers, sharing the same subscriber base or location services, it can cause outages to the data traffic. This is especially prevalent for 5G networks which use IMS for non-voice related services like supporting network slicing and Network Area Tracking. Therefore, the probability of these incidents is considered MEDIUM .	Medium

5.2.8 Fraud

Fraud describes acts of abuse for monetary or other gains. In the context of telecommunications, this often results in fraudulent service usage or fraudulent charges to operators or their subscriber's falling victim to fraud. Considering that IMS and Interconnect subsystems contain network elements relevant for service charging, compromise or abuse of these subsystems has the potential to result in fraud.

Therefore, **both IMS and Interconnect subsystems are considered** as relevant attack domains for the risk scenario Fraud.

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Misconfiguration	Integrity (AP1-I)	Historically, the Interconnect subsystem has been a source of numerous fraud and abuse schemes. While many well-known attacks against legacy protocols can be mitigated by specialized signalling firewalls, attackers also continue to advance their techniques and develop new methods for abusing MNO's and their subscribers for monetary gains. The 5G System includes a dedicated security element, i.e., SEPP, to mitigate this kind of interconnect fraud in 5G roaming scenarios. However, both SEPP and the PRINS protocol are still relatively new and feature complex configurations that operators will have to get experienced with. Therefore, configuration flaws may happen more often as operators roll out 5G roaming for the first time. This configuration complexity is added on top of existing legacy deployments. In the context of the IMS subsystem, misconfiguring rating and charging codes or misclassifying traffic types can lead to charging and billing failure/fraud. Furthermore, misconfigured data gateways can lead to policy and QoS enforcement failure which can also result in abuse. Considering the above points, the probability of these incidents is considered HIGH .	High
Insufficient Access Controls	Integrity (AP2-I)	Access control, specifically, traffic filtering and validation of incoming messages in both IMS and Interconnect domains are essential for preventing abuse. Perimeter security elements (incl. SEPP, UPF/IPUPS, I-SBC) that are not properly setup could allow malicious messages to enter the network and lead to fraudulent charges to MNO or its subscribers, exposure of sensitive information, and other malicious traffic. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Implementation Flaw (Quality of the Product)	Integrity (AP3-I)	Related to insufficient access controls, perimeter security elements may lack appropriate filtering logic or implement flawed filtering mechanisms that would undermine effective security at the interconnect interface. With regards to the IMS subsystem, implementation issues related to the generation, collection, and processing of Charging Data Records can also lead to flawed charging and, by extension, create the potential for fraud and abuse. Since it is assumed that such grave issues would usually be identified through vendors' or operators' testing processes, the probability of these incidents is considered LOW .	Low
Specification Weakness	Integrity (AP4-I)	Technical specifications defining IMS and Interconnect subsystems are usually limited to ensuring technical interoperability of fundamental security controls. As such, they do not explicitly consider fraud and the topic is instead discussed in other industry forums, such as GSMA, which also develops best practices on this issue (see [31] [32]). The absence of guidance on avoiding fraud and abuse in the relevant technical specifications can be considered a specification gap. Therefore, the probability of these incidents is considered HIGH .	High

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Failure of Power Supply	Integrity (AP5-I)	Fraud and abuse concerning the IMS and Interconnect subsystems is not usually a result of a failure of power supply. Therefore, the probability of these incidents is considered LOW .	Low
Failure of Hardware Components or Unavailability of Spare Parts	Integrity (AP6-I)	Fraud and abuse concerning the IMS and Interconnect subsystems is not usually a result of a hardware failure. Therefore, the probability of these incidents is considered LOW .	Low
Design and architecture flaws	Integrity (AP7-I)	Failure to integrate essential security elements into the network design (e.g., SEPP, DEA/DRA, I-SBC) can expose the operator to fraudulent communications. However, such blatant network architecture issues should be caught by internal security reviews at the public MNO. As for IMS, a flawed data gateway design can lead to policy and QoS enforcement failure that can be exploited for monetary, data and legal fraud. Therefore, the probability of these incidents is considered MEDIUM .	Medium

5.2.9 Subscriber Data Leak

Subscriber data leaks happen if personal identifiable data of users are exposed to unauthorized third parties. Considering that the IMS and Interconnect subsystems process User Plane traffic and other subscriber related information, there is a risk for attacks resulting in such exposure.

Therefore, **both IMS and Interconnect subsystems are considered** as relevant attack domains for the risk scenario Subscriber Data Leaks. Worth mentioning, that in this specific attack scenario, the attack describes the data leak of at least 1000 subscriber from the network.

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Misconfiguration	Confidentiality (AP1-C)	Both IMS and Interconnect subsystems handle sensitive information, incl. User Plane traffic, subscriber locations, and other sensitive information which –unless properly protected– may result in a leak of sensitive data. In contrast to the Telecommunication Secrecy scenario, which is mostly concerned with a breach of communication contents and associated metadata, a subscriber data leak may also affect other data points MNOs may store about their customers, such as their home address, billing information, or other personal information. One important aspect of avoiding subscriber data leaks is configuring perimeter security elements such as the SEPP, DEA/DRA, I-SBC, and Security Gateways in such a way that unauthorized parties are not able to access data-in-transit. Another consideration is hardening the network elements themselves, incl. external cloud environments, to minimize the attack surface. Failure to do so can result in exposure of internal interfaces and services that may allow attackers to gain unauthorized access to user related data [33] [34] [35]. The probability of these incidents is considered HIGH . Although public network operators should have sufficiently mature testing and change management processes in place to prevent such breaches of confidentiality, there is still a high likelihood of issues to occur considering the complexity of their technology deployments and thus, the potential attack surface.	High
Insufficient Access Controls	Confidentiality (AP2-C)	Insufficient access control may expose sensitive data at any point of the IMS and Interconnect subsystems that is processing subscriber related information, incl., UPF, A-SBC, and I-SBC. As highlighted in section 5.2.3, these systems are regularly exposed externally, increasing the likelihood of malicious actors to try and obtain access. Moreover, a subscriber data leak may not just be limited to communication contents and associated metadata, but any personal information about the subscriber, such as names, email addresses, and phone numbers. This further increases the spectrum of systems that –when compromised– could lead to such an incident, e.g., business support systems or even the subscriber database. Lastly, not just the network functions themselves, also the platforms hosting them are a potential target for attackers and access to them should be tightly restricted [27]. Therefore, the probability of these incidents is considered HIGH .	High

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Implementation Flaw (Quality of the Product)	Confidentiality (AP3-C)	Implementation flaws in the IMS and Interconnect subsystems can threaten both subscriber related data-in-transit and data-at-rest. Flawed implementations of cryptographic security protocols have the potential to expose data-in-transit (e.g., on interfaces such as N9, N32, or IMS media interfaces). Data-at-rest may be also insufficiently protected due to implementation issues related to, for example, access control, key management, or hardware security. Generally, it is expected that serious issues threatening confidentiality of subscriber related data would be identified and correct during the vendor's or operator's testing processes. Nevertheless, these cannot guarantee the complete absence of implementation flaws and there are real-world examples of implementation vulnerabilities threatening the exposure of sensitive data. A flawed HSM, for example, can seriously endanger the information stored in an MNOs subscriber database HSS/UDM [36]. Therefore, the probability of these incidents is considered HIGH .	High
Specification Weakness	Confidentiality (AP4-C)	Parts of the specification detailing the protection of <i>data-at-rest</i> and <i>data-in-transit</i> may threaten the secrecy of subscriber related data as they are processed by the standard IMS / Interconnect elements and transferred over standard interfaces. For example, an obvious mistake would be the use of weak or vulnerable cryptographic algorithms. However, considering the specification and review process that involves numerous industry stakeholders and, at times, even public review, an error occurring at this stage is rather unlikely. Weaknesses related to non-standard components and interfaces (e.g., management tools, monitoring agents) are considered more likely. Given that their security is entirely up to the individual vendor, design and implementation issues may occur more often at those points. One may consider this an issue caused by <i>underspecification</i> , i.e., the technical specifications not prescribing enough security measures. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Failure of Power Supply	Confidentiality (AP5-C)	A breach of confidentiality is usually not a direct damage resulting from a power supply failure. While it is certainly possible that confidentiality is also breached as part of a more complex incident (e.g., during recovering phase involving third-party service providers), the primary damage is expected in the "Availability" category. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Failure of Hardware Components or Unavailability of Spare Parts	Confidentiality (AP6-C)	A breach of confidentiality is usually not a direct damage resulting from a power supply failure. While it is certainly possible that confidentiality is also breached as part of a more complex incident (e.g., during recovering phase involving third-party service providers), the primary damage is expected in the "Availability" category. Therefore, the probability of these incidents is considered MEDIUM .	Medium

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Design and architecture flaws	Confidentiality (AP7-C)	A subscriber data leak may also be the result of a network design/architecture failure leading to insufficient confidentiality protection of user related data. For example, if important but optional security controls are omitted (e.g., physical security gateways providing protection at the network layer) attackers may be able to access communication contents. However, it is expected that such blatant design flaws would be prevented by a public MNO's security review processes. Therefore, the probability of these incidents is considered LOW .	Low

5.3 User Perspective

This section describes different risk scenarios from the perspective of a user of the public mobile network. Private 5G networks are not in scope of this section. Since some of the risk scenarios one might typically expect here (e.g., emergency calls) are already described in the previous paragraphs, they won't be mentioned again in this section.

5.3.1 Urgent Telephone Calls Not Possible

In addition to the day-to-day phone calls and short text messages, IMS plays a vital role in the emergency reporting and responding infrastructure as well as delivering high-priority calls from diplomats, business users, logistics and government authorities, making IMS a critical part of the nation's infrastructure. Issues arising on the IMS can have cascading effects from failure to report and respond to emergencies all the way to loss of revenue from enterprises who lost calls to their call centers and field workers.

For this reason, **the IMS subsystem is considered** a relevant attack domain for the risk scenario Urgent Telephone Calls Not Possible. Conversely, **Interconnect is not considered**.

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Misconfiguration	Availability (AP1-A)	Misconfiguration of IMS elements may lead to degradation in service quality or even unavailability of voice service. This includes SIP routing functions such as, P-CSCFs, S-CSCFs, BCGFs, and other network components. In the worst case, this can affect emergency calls and other mission critical services. Situations where misconfigurations can occur are numerous, incl. regular maintenance and rollout of new hardware which have led to issues with emergency services availability in the past [24], [25]. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Insufficient Access Controls	Availability (AP2-A)	The risk of insufficient access control to IMS or Interconnect components is the same as for any other central part of the network. Although it is not usually a direct result of flawed access control, access control for any system supporting voice services should be setup as restrictive as possible to minimize the risk of service disruption. Considering that the relevant IMS components are deployed in a central location of the network with few stakeholders having direct access to them, the probability of these incidents is considered LOW .	Low
Implementation Flaw (Quality of the Product)	Availability (AP3-A)	Implementation flaws can occur at multiple points between UE and IMS. However, it is unlikely that critical flaws threatening the availability of voice services would go unnoticed by the vendors' and MNO's testing processes. Therefore, the probability of these incidents is considered LOW .	Low

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Specification Weakness	Availability (AP4-A)	Availability failures are generally not a direct result of a specification weakness. For ensuring availability, design, implementation, and test are much more relevant (see also “Design and architecture flaws” below). Therefore, the probability of these incidents is considered LOW .	Low
Failure of Power Supply	Availability (AP5-A)	Failure of power supply affecting IMS components can impact the availability of different services. For example, unavailability of a CSCF handling SIP sessions from subscribers in a certain area would likely also affect their ability to make voice calls. The reason for power outages may include unintentional defects [26], intentional sabotage, external issues at the power grid operator, or environmental conditions like the previously mentioned [20]. Although public MNOs are expected to have adequate controls in place to prevent these incidents from happening (e.g., redundant access to power grids, uninterruptable power supplies, generators), not all aspects of the power supply are under the control of the MNO itself, and the real-world examples of power failures leading to datacentre outages (see [20]) exemplifies that the risk is significant. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Failure of Hardware Components or Unavailability of Spare Parts	Availability (AP6-A)	Failure of hardware components associated with central IMS elements can impact the availability of voice services. However, it is expected that MNOs would generally have redundancy and recovery capacity at the IP, Core and IMS infrastructure level in place to prevent isolated hardware failures from impacting the service layer – especially for mission critical services (see also “Design and architecture flaws” below). Overall, the probability of these incidents occurring is low with most operators unless no sufficient hardware & system redundancy is available or the failover mechanism between the Core, IMS and IP infrastructure is unharmonized, in this case the probability can be considered MEDIUM .	Medium
Design and architecture flaws	Availability (AP7-A)	Network performance issues are common and one major cause is IMS topology and design in which poor scalability, single points of failures, inefficient traffic routing, lack of redundancy, inadequate uplink bandwidth and weak load balancing mechanisms are all issues that MNOs face that create circumstances in which the QoS of the connection is impacted. Ideally, such issues should be distributed across the service area, so that a regional incident does not affect all critical components at once, possibly impairing call quality/availability. It is assumed that MNOs take these considerations into account during their deployment planning and, in the event of a local availability issue, would usually have the ability to compensate by adequate recovery sites and the ability to switch over. Overall, the probability of these incidents is considered MEDIUM .	Medium

5.3.2 Authenticity of the Receiver of a Call

Spoofing or otherwise meddling with the authenticity of the called party is not a very common attack, in contrast to the spoofing of caller identities. Nevertheless, there is a theoretical possibility that an attacker infiltrates the MNO's network barriers and compromises related IMS / Interconnect functions involved in call setup or call forwarding.

Therefore, **IMS and Interconnect subsystems are considered** as relevant attack domains for the risk scenario Authenticity of the Receiver of a Call.

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Misconfiguration	Integrity (AP1-I)	While a misconfiguration issue or a lack of hardening may allow malicious parties to gain unauthorized access to IMS and/or Interconnect elements, An attacker might try gaining access to critical information processed by these subsystems (e.g., at the HSS/UDM). That being said, it is worth noting that when an attacker does gain access to particular nodes (e.g., P/I/S-CSCF, PCF, HSS/UDM), it is possible to cause all types of media failures like call-barring, roaming-barring, SMS failure, number-specific policy, call routing, dropping, declining...etc. However, given the fact that these central network elements are generally well protected, isolated from one another and equipped with OSS-triggered alarms, the probability of these incidents happening is considered LOW .	Low
Insufficient Access Controls	Integrity (AP2-I)	While a malicious actor may be technically able to reroute calls at the network level once they have gained access to central IMS and/or Interconnect elements, there are other objectives that the attacker might also consider like critical information processed by these subsystems (e.g., at the HSS/UDM) That being said, it is worth noting that when an attacker does gain access to particular nodes (e.g., P/I/S-CSCF, PCF, HSS/UDM), it is possible to cause all types of media failures like call-barring, roaming-barring, SMS failure, number-specific policy, call routing, dropping, declining...etc. However, given the fact that these central network elements are generally well protected, isolated from one another and equipped with OSS-triggered alarms, the probability of these incidents happening is considered LOW .	Low
Implementation Flaw (Quality of the Product)	Integrity (AP3-I)	While an implementation failure may lead to calls not being properly routed to the correct receiver, it is expected that such grave functional issues would likely be caught by the vendor's or MNO's testing processes. Beyond that, there is no end-to-end authentication scheme between calling party and called party (see "Specification Weakness"). Therefore, the probability of these incidents is considered LOW .	Low
Specification Weakness	Integrity (AP4-I)	At this point, there is no standardized technical solution for the authentication of the receiver of a call. The much more relevant (and frequently abused) scenario is spoofing the identity of the calling party. To counteract this, there have been several initiatives aimed at performing caller ID authentication (e.g., STIR/SHAKEN by ATIS), so that the receiver can be certain that the calling number displayed on their phone has not been spoofed. However, these too have failed to achieve unanimous adoption at a global level [37]. Overall, the lack of caller ID authentication (and to some extent authentication of the called party) can be considered an issue due to severe <i>underspecification</i> in the relevant technical specifications. Since caller ID spoofing is the much more severe threat than a malicious party rerouting/spoofing the authenticity of the receiving party at the network level, the probability of these incidents is considered LOW .	Low

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Failure of Power Supply	Integrity (AP5-I)	No specific attack paths related to Failure of Power Supply have been identified.	Low
Failure of Hardware Components or Unavailability of Spare Parts	Integrity (AP6-I)	No specific attack paths related to Failure of Hardware Components have been identified.	Low
Design and architecture flaws	Integrity (AP7-I)	No specific attack paths related to Design and architecture flaws have been identified.	Low

5.3.3 Integrity of Transmitted Data

As defined in the risk scenarios, data in this case refers to non-voice related data excluding signaling and SIP handling messages of the call. The Interconnect subsystem, specifically the UPF and the N9 interface, regularly process and transport this kind of data. On the other hand, IMS is not concerned with providing the end users with data access, providing policy and charging control, nor enforcing QoS or inspection on this type of 5G user data. It is worth mentioning that IMS control plane and user plane might follow similar channels and share the same IP infrastructure, however, the IMS has no direct oversight or influence over this data.

For this reason, **the Interconnect subsystem is considered** as a relevant attack domain for the risk scenario Integrity of Transmitted Data. Conversely, **IMS is not considered**.

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Misconfiguration	Integrity (AP1-I)	Misconfiguration in the Interconnect subsystem may lead to insufficient protection of user data transmitted over the N9 interface. Although the technical specifications mandate the enforcement of integrity protection, this should always be confirmed by the MNO itself. Particularly in the case of N9, which connects 5G network domains controlled by different parties, there is quite a high potential for misconfigurations to occur. In practice, a single MNO may need to setup and configure dozens of N9 connects to different roaming partners, roaming hubs, and other service providers. Nevertheless, validating successful integrity protection (and other security controls) should be an essential step in this process, so that major misconfigurations are caught by the MNO's testing and change management processes early on. Therefore, the probability of these incidents is considered MEDIUM .	Medium

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Insufficient Access Controls	Integrity (AP2-I)	Insufficient access control may allow an attacker to compromise a UPF instance. Once such an actor is in control of this Network Function, it would be possible to alter user related data-in-processing. Considering that the UPF is part of the 5G Core Network and would usually be deployed in a central network location protected by strict, multi-level security controls, this scenario is considered rather unlikely. Moreover, since a single UPF instance may process the data of hundreds of individual subscribers, targeted attacks would be difficult to realize and other Network Functions in the 5G Core (e.g., HSS/UDM) hold data more valuable to attackers. Therefore, the probability of these incidents is considered LOW .	Low
Implementation Flaw (Quality of the Product)	Integrity (AP3-I)	Implementation flaws related to cryptographic security protocols (e.g., IPSec, TLS) protecting data-in-transit on User Plane interfaces, such as N9, have the potential to impact data integrity. Abusing insecure implementations, attackers may be able to alter communication contents. In addition, implementation issues with the relevant Network Functions themselves may additionally pose a risk as well. Although grave issues threatening the integrity or confidentiality of User Plane traffic should be caught by vendor's and the MNO's testing processes, there is still a chance for such issues to go unnoticed. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Specification Weakness	Integrity (AP4-I)	The 3GPP technical specifications mandate that "Roaming interfaces between PLMNs except for N32, shall be confidentiality, integrity, and replay protected" (see TS 33.501 [1], section 9.9). This includes the N9 interfaces between UPFs transporting user related data. While such a mandate alone does not guarantee the absence of specification weaknesses (e.g., they may still contain references with weak or vulnerable cryptographic algorithms), the authors are not aware of such an issue related to the protection of 5G user data. Considering the specification and review process that involves numerous industry stakeholders and, at times, even public review, an error occurring at this stage is rather unlikely. Therefore, the probability of these incidents is considered LOW .	Low
Failure of Power Supply	Integrity (AP5-I)	Integrity issues are generally not a direct result of a failure of power supply. Therefore, the probability of these incidents is considered LOW .	Low
Failure of Hardware Components or Unavailability of Spare Parts	Integrity (AP6-I)	Integrity issues are generally not a direct result of a hardware failure. Therefore, the probability of these incidents is considered LOW .	Low
Design and architecture flaws	Integrity (AP7-I)	No specific attack paths related to Design and architecture flaws have been identified.	Low

5.3.4 User's Identity

Both IMS as well as the Interconnect subsystem process various types of user identities, such as phone numbers and the permanent SUPI. An attacker may be able to access and misuse someone's identity by various methods including spoofing, tampering, or intercepting communications.

Therefore, **IMS and Interconnect subsystems are considered** as relevant attack domains for the risk scenario User's Identity.

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Misconfiguration	Confidentiality (AP1-C)	A number of configuration flaws related to the protection of data-in-transit as well as security of the IMS network elements themselves can lead to user's identity being compromised, incl. inadequate user authentication, a lack of IPSec, weak cryptographic profiles, and unnecessary exposure of network APIs (e.g., through NEF). It is therefore crucial to adhere to best practices for IMS configuration and security hardening. Similarly, misconfiguration in the Interconnect subsystem may lead to insufficient protection of user identities transmitted over the N32 interface (e.g., SUPI, phone numbers). Although the technical specifications mandate such identities to be protected, this should always be confirmed by the MNO itself. Although there are several sources for potential misconfigurations, as outlined above, such major misconfigurations/ hardening flaws should be caught by the MNO's testing and change management processes early on. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Insufficient Access Controls	Confidentiality (AP2-C)	Although not a common attack path, one mishap is when MNOs allow certain subscribers to access restricted resources through APNs which can be requested by subscribers due to no provisioning restrictions. Test APNs are often not removed once initial network inauguration is completed. There is no direct risk to the user's identity here, so the probability is considered LOW . Nevertheless, such network exposure might contribute to increasing the attack surface of a certain user group (ex. A business group with a dedicated APN and IP Pool).	Low

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Implementation Flaw (Quality of the Product)	Confidentiality (AP3-C)	Implementation flaws can have serious consequences on the user's identity, for example, by not supporting the use of IPSec by Small IMS vendors and implementations based on some Open-source IMS solutions due to the added overhead complexity IPSec brings to the solution. Although this security flaw is well-known, subscribers may still transmit SIP messages in plain text. Therefore, the messages are easily injected into the SIP session by the attacker. Moreover, the owner of a bearer for registering to the IMS server can be different from the actual registered person using the bearer. An attacker can set up a bearer in advance and then register to the IMS as a victim to enjoy SMS services by exploiting the vulnerability (see also [38]). Worth mentioning that the not-mandating IPSec problem is not exclusive to the Product Implementation but can also happen during the solution Design phase as it would be highlighted in the low-level design due to its added processing requirement from the IMS nodes, the routers and associated servers. Besides that, IPSec can also be disabled after product commissioning due to IPSec misconfiguration. The probability is considered MEDIUM as several new IMS providers are entering the market with focus on purpose-built proof of concept solutions like SBA-powered IMS, Mission-Critical-only IMS and Open IMS solutions that might lack security requirements concerning the protection of the user's identity.	Medium
Specification Weakness	Confidentiality (AP4-C)	The technical specifications play a major role in concealing user identities in every component and on every interface that handles this kind of data (incl., N32, Gm, Mw). However, considering the specification and review process that involves numerous industry stakeholders and, at times, even public review, an error occurring at this stage is rather unlikely. So far, there have been no major concerns over weaknesses in the 5G technical specifications impacting user identities. Therefore, the probability of these incidents is considered LOW .	Low
Failure of Power Supply	Confidentiality (AP5-C)	Confidentiality breaches, and specifically User identity leaks, are generally not a direct result of a failure of power supply. Therefore, the probability of these incidents is considered LOW .	Low
Failure of Hardware Components or Unavailability of Spare Parts	Confidentiality (AP6-C)	Confidentiality breaches, and specifically User identity leaks, are generally not a direct result of a hardware failure. Therefore, the probability of these incidents is considered LOW .	Low

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Design and architecture flaws	Confidentiality (AP7-C)	Design and architectural weaknesses in mobile networks can significantly compromise a user's identity. A good example of this is when 5G network users, who aim to use the IMS, revert back to using 4G LTE through EPS Fallback mechanism for voice calls. Due to design flaws, this fallback process can leave users susceptible to identity-related risks. An attacker can set up a 4G False Base Station (FBS), and lure victim devices to connect to it. The mobile devices will try to access the 2G/3G network when they find that they cannot register to the 4G network to complete the call. Once connected to FBS, the attacker can exploit the lack of authentication during the Circuit Switched Fallback (CSFB) process, intercept the user's communication, or exploit transmitted security contexts, potentially leading to unauthorized access to sensitive information and hence a compromise of the user's identity. As 2G and 3G are still commonly used, MNOs must design their EPS and CS Fall back very carefully not to compromise the user's identity. Some operators have started decommissioning their 2G and 3G network and are therefore safe from this exploit (see [39]). Therefore, the probability of an attack remains medium as long as the MNO uses 2G and 3G networks. (See also [40] for further attack details). Therefore, the probability of these incidents is considered MEDIUM .	Medium

5.3.5 Eavesdropping of a Communication

IMS and Interconnect subsystems both process user related data and have the potential to expose this information to malicious actors, unless properly protected. In the case of IMS, attackers may be able to access data related to (potentially mission critical) voice services, while Interconnect interfaces like N9 carry other user related data of inbound and outbound roamers.

Therefore, **IMS and Interconnect subsystems are considered** as relevant attack domains for the risk scenario Eavesdropping of a Communication.

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Misconfiguration	Confidentiality (AP1-C)	Both IMS and Interconnect subsystems handle User Plane data of subscribers which – unless properly protected – may allow Eavesdropping of Communication. On one hand, data-in-transit may be exposed to unauthorized parties on IMS media interfaces (e.g., between the UE and the A-SBC). On the other hand, there is a risk of exposing such data to external parties on Interconnect links, e.g., on the N9 interface between UPF instances and between I-SBC instances in different IMS domains. The probability of these incidents is considered Medium. Although public network operators should have sufficiently mature testing and change management processes in place to prevent such breaches of confidentiality, there is still a significant likelihood of issues to occur, e.g., because of regular maintenance. Limiting the likelihood is the fact that, in contrast to a breach of “Telecommunication Secrecy” or a “Subscriber Data Leak”, this risk scenario assumes a breach of the communication contents themselves, excl. associated metadata. Therefore, the probability of these incidents is considered MEDIUM .	Medium

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Insufficient Access Controls	Confidentiality (AP2-C)	Insufficient access control may expose subscribers' communication contents at any network function that handles User Plane traffic, incl. UPF, A-SBC, and I-SBC. Considering these network elements are situated at the network perimeter, they are highly exposed to malicious actors, though MNOs are expected to have sufficiently mature operational practices in place to ensure access to them is adequately restricted. In contrast to a breach of Telecommunication Secrecy, this risk scenario assumes a breach of the communication contents specifically, which limits the components/interfaces where such a breach could occur. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Implementation Flaw (Quality of the Product)	Confidentiality (AP3-C)	Implementation flaws related to cryptographic security protocols (e.g., IPSec, TLS) protecting data-in-transit on User Plane interfaces, such as N9, may allow for Eavesdropping of Communication. By abusing insecure implementations, attackers may be able to access communication contents. In addition, implementation issues with the relevant Network Functions themselves may pose an additional security risk. Although grave issues threatening the confidentiality of User Plane traffic should be caught by vendor's and the MNO's testing processes, there is still a chance for such issues to go unnoticed. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Specification Weakness	Confidentiality (AP4-C)	Specific elements of the IMS and 5G specifications that detail the safeguarding of data-at-rest and data-in-transit could potentially pose a risk to the confidentiality of User Plane traffic processed by the standard IMS / Interconnect elements (e.g., UPF, A-SBC, I-SBC) and transferred over standard interfaces (e.g., N9, IMS media interfaces). For example, an obvious mistake would be the use of weak or vulnerable cryptographic algorithms. However, considering the specification and review process that involves numerous industry stakeholders and, at times, even public review, an error occurring at this stage is rather unlikely. Weaknesses related to non-standard components and interfaces (e.g., management tools, monitoring agents) are considered more likely. Given that their security is entirely up to the individual vendor, design and implementation issues may occur more often at those points. One may consider this an issue caused by <i>underspecification</i> , i.e., the technical specifications not prescribing enough security measures. Therefore, the probability of these incidents is considered LOW .	Low
Failure of Power Supply	Confidentiality (AP5-C)	A breach of confidentiality is usually not a direct damage resulting from a power supply failure. While it is certainly possible that confidentiality is also breached as part of a more complex incident (e.g., during recovering phase involving third-party service providers), the primary damage is expected in the "Availability" category. Therefore, the probability of these incidents is considered LOW .	Low

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Failure of Hardware Components or Unavailability of Spare Parts	Confidentiality (AP6-C)	A breach of confidentiality is usually not a direct damage resulting from a hardware failure. While it is certainly possible that confidentiality is also breached as part of a more complex incident (e.g., during maintenance involving third-party service providers), the primary damage is expected in the “Availability” category. Therefore, the probability of these incidents is considered LOW .	Low
Design and architecture flaws	Confidentiality (AP7-C)	Eavesdropping of Communication may also be the result of a network design/architecture failure leading to insufficient confidentiality protection of user related data. For example, if important but optional security controls are omitted (e.g., physical security gateways providing protection at the network layer) attackers may be able to access communication contents. However, it is expected that such blatant design flaws would be prevented by an MNO’s security review processes. Therefore, the probability of these incidents is considered Low. IMS users might subsequently face eavesdropping due to flaws in the 5G network design that makes IMSI traps a problem. Despite EPS-AKA mutual authentication and strong encryption algorithms, attackers can steal IMSIs by capturing signalling messages that are broadcast as plaintext to all surrounding base stations (or IMSI Catchers) [41]. Therefore, the probability of these incidents is considered LOW .	Low

5.3.6 Slowing Down/Restricting the Connection

Slowing down or restricting connections is a common issue with IMS where the Quality of Service is a major factor for its functionality. This can easily be impacted by network disturbance, policy enforcement, insufficient network timers and voice tuning settings. Most of the time, these settings are pre-shipped with the solution but also need to be tailored towards specific dynamic scenarios like network overcapacity during peak-hours, high latency tolerance and even jamming.

Therefore, **the IMS subsystem is considered** as a relevant attack domain for the risk scenario Slowing Down and Restricting the Connection. Conversely, **Interconnect is not considered**.

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Misconfiguration	Availability (AP1-A)	Incorrectly configured QoS policies misclassifying certain traffic or failing to prioritize voice and media traffic over normal data traffic can cause degradation of service quality. Similarly, IMS handles multiple timers that impact the quality and clarity of the call. The exact timer values are not always standardized and are rarely changed after the initial IMS setup, potentially impairing service quality. In addition, business subscribers might be impacted if their business-specific APN is not prioritized over APNs serving general subscribers or is not granted higher bitrate to pass traffic during rush hours. Therefore, the probability of these incidents is considered HIGH .	High
Insufficient Access Controls	Availability (AP2-A)	No specific attack paths related to Insufficient Access Control have been identified.	Low
Implementation Flaw (Quality of the Product)	Availability (AP3-A)	IMS is prone to suffering from NAT traversal issues, especially with misconfigured Session Border Controllers. This could slow down connections or even prevent certain traffic from getting through to the user. However, as these parameters are tested vigorously during the go-live phase of the IMS network, it is expected that such flaws would usually be identified and fixed early on. The probability of these incidents is considered LOW .	Low
Specification Weakness	Availability (AP4-A)	3GPP TS 23.107 regarding QoS and architecture including traffic class specification, TS 26.131 regarding Speech and Audio, TS 23.228 for IMS Stage 2 with emphasis on voice quality, 23.203 for Policy and Charging control as well as the TS 26.114 for conversational multimedia coding are all 3GPP specifications that regulate, advise on and support the implementation of a robust IMS network that ensures redundancy and acceptable quality of media by indicating delay buckets, priorities, codex, IP handling and much more. Given the maturity of these documents, specification weaknesses are rarely the culprit of a degraded connection performance for the user and the probability of these incidents is considered LOW .	Low
Failure of Power Supply	Availability (AP5-A)	Power outages on load balancing or supporting routers could potentially cause service degradation specifically during peak hours where more traffic is foreseen. It can be expected that those components would usually be deployed in a redundant fashion and operators have measures in place to compensate for temporary power supply failures (e.g., through alternative power sources, redundancy, or failover sites). Nevertheless, existing connections may still be temporarily impacted while, for example, traffic is routed to different system instances or processing occurs only at failover sites. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Failure of Hardware Components or Unavailability of Spare Parts	Availability (AP6-A)	Hardware failure on load balancing or supporting routers could potentially cause service degradation specifically during peak hours where more traffic is foreseen. Additionally, IMS systems of vendors who are out of business or vendors that utilize legacy systems (like HLR, GGSN and SGSN) that might share part of their provisioning infrastructure with IMS might have difficulty servicing their legacy systems with required support and spare parts. This is, however, very unlikely as IMS systems are more modern and prevalent with LTE and 5G networks and are more likely to share their HSS/UDM provisioning databases than with legacy networks. Therefore, the probability of these incidents is considered LOW .	Low

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Design and architecture flaws	Availability (AP7-A)	Network performance issues are very common and one major cause is IMS topology and design in which poor scalability, single points of failures, inefficient traffic routing, lack of redundancy, inadequate uplink bandwidth and weak load balancing mechanisms are all issues that MNOs face, creating circumstances in which the QoS of the connection is impacted. Therefore, the probability of these incidents is considered HIGH .	High

5.3.7 Connection Failure

Call-drops are also a common phenomenon in Voice over IP systems specifically when network configuration or design doesn't account for packet loss and high latency times. As mentioned in Chapter 5.3.6 (Slowing Down/Restricting the Connection), these intricate timers are often tuned and tested multiple times to ensure the call doesn't drop or timeout during peak hours. Nevertheless, the underlaying IP network can suffer from diverse issues causing the call to drop midway or the policy and charging rules might not be a good fit for specific users (like business users) and the IMS system should cope accordingly, making the connection failure a relevant attack domain from the user's perspective.

Therefore, **IMS and Interconnect subsystems are considered** as relevant attack domains for the risk scenario Connection Failure.

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Misconfiguration	Availability (AP1-A)	Misconfigured QoS parameters or timers, among many things, can lead to time outs and eventually connection failure with both Mobile Originating (MO) and Mobile Terminating (MT) connections. For roaming, misconfigured IMSI blocks or PLMNs at the visited network or incorrect global title translation according to ITU-U (Q.713) can lead to call failure, both with MO and MT. Connection failure during roaming is more common as both the home and visited network need to constantly keep their roaming agreement updated, this includes but is not limited to, global titles, PLMNs, whitelisted perimeter IP addresses, roaming exchanges, eDNS records and other information that is regulated in the RAEX IR. 21 Roaming Database. Therefore, the probability of these incidents is considered HIGH .	High
Insufficient Access Controls	Availability (AP2-A)	No specific attack paths related to Insufficient Access Control have been identified.	Low
Implementation Flaw (Quality of the Product)	Availability (AP3-A)	Implementation flaws in both IMS and Interconnect components can lead to individual connection failures, e.g., due to mishandling of certain edge cases. While there is no way to guarantee for the absence of these issues, it is expected that severe issues resulting in dropped connections should be caught by vendor's and the MNO's testing processes. Therefore, the probability of these incidents is considered LOW .	Low

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Specification Weakness	Availability (AP4-A)	Specification weakness would likely lead to more severe issues than dropping individual connections. In addition, it is likely that severe issues would be caught by one of the many industry stakeholders during standardization or testing and fixed prior to getting into real-world deployments. Even though IMS is often underrepresented by 3GPP in 5G networks design specifications in their early releases (TS 23.501 Rel. 15 and Rel. 16), other 3GPP specifications address connections failures that can stem from QoS or flawed design in TS 23.107 regarding QoS and architecture including traffic class specification, TS 23.228 for IMS Stage 2, 24.229 for flows and call setup procedures as well as SIP error handling. Therefore, specification weakness is rarely the culprit of a MO or MT failed connection, and the probability of these incidents is considered LOW .	Low
Failure of Power Supply	Availability (AP5-A)	Power outages affecting the infrastructure of central IMS and/or Interconnect elements may have a negative impact on established connections. It is expected that these important network elements would be deployed in central data centers featuring sufficient redundancy and appropriate controls to compensate for temporary power supply failures (e.g., through redundant connections to the electricity grid, uninterruptable power supplies, alternative power sources, etc.). Nevertheless, existing connections may still be temporarily impacted while, for example, traffic is routed to different system instances or processing occurs only at failover sites. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Failure of Hardware Components or Unavailability of Spare Parts	Availability (AP6-A)	Failure of individual components is not expected to lead to a connection failure, as operators should have sufficient redundancy and failover potential in place to prevent isolated HW failures from affecting the service layer. Therefore, the probability of these incidents is considered LOW .	Low
Design and architecture flaws	Availability (AP7-A)	Network performance issues are very common and one major cause is IMS topology and design in which poor scalability, single points of failures, inefficient traffic routing, lack of redundancy, inadequate uplink bandwidth and weak load balancing mechanisms are all issues that MNOs face that create circumstances in which the QoS of the connection is impacted. The probability of such issues to result in dropped connections is considered MEDIUM .	Medium

5.3.8 Tapping or Altering of the Geographical Position

Since IMS is generally not involved in the location registration and location update procedures, it can be ruled out as a potential attack source. IMS users might suffer from an altered geographical position as a result of the core network being compromised, but nevertheless, IMS has no direct influence here. On the contrary, the Interconnect subsystem processes different types of location data, incl. the Cell ID of the base station currently associated to a subscriber. Moreover, attacks against legacy mobile network generations have shown that attackers may even be able to access the subscriber data base ([6]), which contains location data among other sensitive information, via the signaling interface.

For this reason, **the Interconnect subsystem is considered** a relevant attack domain for the risk scenario Tapping or Altering of the Geographical Position. Conversely, **IMS is not considered**.

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Misconfiguration	Confidentiality (AP1-C)	Misconfiguration of N32 security controls in the SEPP may lead to exposure of location data on the N32 interconnect interface. Given that PRINS is a new protocol, and the protection is to be specified very granularly (based on Information Element type), the risk may be higher for MNOs to misconfigure these when initially adopting 5G roaming. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Insufficient Access Controls	Confidentiality (AP2-C)	As a crucial security element for enforcing access control on the 5G network perimeter, the SEPP also protects 5G NFs storing or otherwise processing subscriber location data. Generally, it would be expected that MNOs have sufficiently mature hardening and testing processes in place to avoid unauthorized access from outside their network – both to the SEPP itself as well as to the 5G NFs situated behind it. However, considering that malicious interconnect messages have historically been a major source of fraud and abuse, incl. spying on subscribers' location [6], the probability of these incidents is considered MEDIUM . Insufficient filtering of incoming messages by the SEPP may allow attackers to mount such attacks.	Medium
Implementation Flaw (Quality of the Product)	Confidentiality (AP3-C)	Implementors may make mistakes in adequately protecting the Information Elements that are mandatory to be encrypted on the N32 interface. Furthermore, implementation of cryptographic algorithms themselves may be flawed, incl. associated aspects such as key management, which can have an impact on confidentiality of data-in-transit. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Specification Weakness	Confidentiality (AP4-C)	Specifications may miss prescribing confidentiality protection on the N32 interface for Information Elements containing location data. Considering that new Information Elements can be added over the lifetime of the 5G System, there is a chance for some of them to be missed in the security specifications, although they are not expected to change very frequently. Therefore, the probability of these incidents is considered MEDIUM .	Medium
Failure of Power Supply	Confidentiality (AP5-C)	A confidentiality breach is usually not a direct damage resulting from a power supply failure. While it is certainly possible that confidentiality is also breached as part of a more complex incident (e.g., during recovering phase involving third-party service providers), the primary damage is expected in the “Availability” category. Therefore, the probability of these incidents is considered LOW .	Low
Failure of Hardware Components or Unavailability of Spare Parts	Confidentiality (AP6-C)	A confidentiality breach is usually not a direct damage resulting from a damaged hardware component or unavailable spare-part. While it is certainly possible that confidentiality is also breached as part of a more complex incident (e.g., during recovering phase involving third-party service providers), the primary damage is expected in the “Availability” category. Therefore, the probability of these incidents is considered LOW .	Low

Attack Path Category	Attack Path ID	Probability Description	Probability Level
Design and architecture flaws	Confidentiality (AP7-C)	No specific attack paths related to Design and architecture flaws have been identified.	Low

5.4 Private 5G Network Operator Perspective

Note: The following assumptions apply for these risk scenarios for the private 5G network perspective.

- This scenario is only focussed on on-premise networks.
- The network's backbone is part of the organization's general IT network.
- The network is separated by a firewall, which is part of the 5G network, from the public network.
- The network does not have Multi Access Edge Computing (MEC) or an IP Multimedia Subsystem.
- This perspective considers networks that are limited to dedicated locations.
- Organizations might operate multiple locations with separate private 5G networks.
- The members of the organization operating the network are also the user of the network. There is no separate group of users or a separate operator.

It is worth mentioning that some private 5G vendors might opt for including IMS or stripped-down IMS solutions to provide Mission-Critical-Communication functionality to the Private 5G sphere, however, in these situations the risk can be generally assumed to be the same as for the Public Mobile Network Providers.

5.4.1 Network Failure

It is not foreseen to have IMS integrated to Private 5G deployments or to have them interconnect with other 5G networks, therefore ruling out the IMS and Interconnect subsystems as a potential attack domain for the risk scenarios Network Failure.

5.4.2 Degraded Services / Connections

Since IMS and Interconnect subsystems are generally not part of Private 5G deployments, neither of them is considered as a potential attack domain for the risk scenarios Degraded Services / Connections.

5.4.3 Information Disclosure

Since IMS and Interconnect subsystems are generally not part of Private 5G deployments, neither of them is considered as a potential attack domain for the risk scenarios Information Disclosure.

5.4.4 User Identities (Authenticity/Integrity)

Since IMS and Interconnect subsystems are generally not part of Private 5G deployments, neither of them is considered as a potential attack domain for the risk scenarios User Identities.

6 Risk Assessment Results

This chapter presents the final results of the detailed risk analysis. The final risk analysis that covers all subsystems is presented in the framework document.

Note: Risk scenarios with no given probability level were not rated, see beginning of Chapter 5 and the corresponding risk scenario.

6.1 Probability Assessment

The following table summarizes the results of this detailed analysis of the **IMS and Interconnect network**. According to the maximum principle in risk analysis only the highest probability is listed.

Perspective	Section	Risk Scenario	Probability Level
Public MNO	5.2.1	Emergency Call (TKG § 164)	Medium
	5.2.2	Cell Broadcast (TKG § 164a)	
	5.2.3	Telecommunications Secrecy (TTDSG § 3)	High
	5.2.4	Emergency Preparedness (TKG § 184)	High
	5.2.5	Regional Network Failure	
	5.2.6	Multi-Regional Network Failure	
	5.2.7	Failure of Mobile Service	Medium
	5.2.8	Fraud	High
	5.2.9	Subscriber-Data Leak	High
User	5.3.1	Urgent Telephone Calls Not Possible	Medium
	5.3.2	Authenticity of the Receiver of a Call	Low
	5.3.3	Integrity of Transmitted Data	Medium
	5.3.4	User's Identity	Medium
	5.3.5	Eavesdropping of a Communication	Medium
	5.3.6	Slowing Down/Restricting the Connection	High
	5.3.7	Connection Failure	High
	5.3.8	Tapping or Altering of the Geographical Position	Medium
Private 5G Network Operator	5.4.1	Network Failure	
	5.4.2	Degraded Services/Connections	
	5.4.3	Information Disclosure	
	5.4.4	User Identities (Authenticity/ Integrity)	

6.2 Risk Assessment

The following table summarizes the overall risk assessment of the **IMS and Interconnect network**. The risk scenarios and their respective impact level are described in the framework document.

Perspective	Risk Scenario	Impact	Probability	Risk Score
Public MNO	Emergency Call (TKG § 164)	High	Medium	High
	Cell Broadcast (TKG § 164a)			
	Telecommunications Secrecy (TTDSG § 3)	Medium	High	High
	Emergency Preparedness (TKG § 184)	High	High	High
	Regional Network Failure			
	Multi-Regional Network Failure			
	Failure of Mobile Service	Medium	Medium	Medium
	Fraud	Low	High	Medium
	Subscriber-Data Leak	Medium	High	High
User	Urgent Telephone Calls Not Possible	Low	Medium	Low
	Authenticity of the Receiver of a Call	Medium	Low	Low
	Integrity of Transmitted Data	High	Medium	High
	User's Identity	High	Medium	High
	Eavesdropping of a Communication	Medium	Medium	Medium
	Slowing Down/Restricting the Connection	Low	High	Medium
	Connection Failure	Low	High	Medium
	Tapping or Altering of the Geographical Position	High	Medium	High
Private 5G Network Operator	Network Failure			
	Degraded Services/Connections			
	Information Disclosure			
	User Identities (Authenticity/ Integrity)			

Bibliography

- [1] 3GPP, "TS 33.501; Security architecture and procedures for 5G System; V18.6.0".
- [2] "Yokogawa STARDOM," [Online]. Available: <https://www.cisa.gov/news-events/ics-advisories/icsa-22-174-01>.
- [3] "Motorola Solutions MDLC," [Online]. Available: <https://www.cisa.gov/news-events/ics-advisories/icsa-22-179-05>.
- [4] "T-Mobile Breach via exposed test equipment," [Online]. Available: <https://www.darkreading.com/cyberattacks-data-breaches/more-than-47m-affected-in-t-mobile-breach>.
- [5] "Faulty firewall," [Online]. Available: <https://arstechnica.com/tech-policy/2024/06/faulty-firewall-blocked-911-calls-throughout-massachusetts-for-two-hours/>.
- [6] "ENISA Signalling Security in Telecom SS7/Diameter/5G," [Online]. Available: <https://www.enisa.europa.eu/publications/signalling-security-in-telecom-ss7-diameter-5g/@download/fullReport>.
- [7] "Ex-Employee's Admin Credentials Used in US Gov Agency Hack," [Online]. Available: <https://www.securityweek.com/ex-employees-admin-credentials-used-in-us-gov-agency-hack/>.
- [8] "SMS spoofing attack due to the service's weak authorization," [Online]. Available: <http://library.usc.edu/ph/ACM/SIGSAC%202017/ccs/p1118.pdf>.
- [9] "Emerson OpenBSI," [Online]. Available: <https://www.cisa.gov/news-events/ics-advisories/icsa-22-221-03>.
- [10] "ENISA Signalling Security in Telecom SS7/Diameter/5G," [Online]. Available: <https://www.cisa.gov/news-events/ics-advisories/icsa-22-221-03>.
- [11] "Heartbleed Bug," [Online]. Available: <https://heartbleed.com/>.
- [12] "Motorola Solutions MDLC," [Online]. Available: <https://www.cisa.gov/news-events/ics-advisories/icsa-22-179-05>.
- [13] "CVE-2007-1112," [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2007-1112>.
- [14] "Philips Intellispace Portal ISP Vulnerabilities," [Online]. Available: <https://www.cisa.gov/news-events/ics-medical-advisories/icsma-18-058-02>.
- [15] "CVE-2020-7218," [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2020-7218>.
- [16] "CVE-2002-1876," [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2002-1876>.
- [17] "CVE-2008-3571," [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2008-3571>.
- [18] "IMS: a Standard for Standards Bodies," [Online]. Available: <https://technews.tmcnet.com/channels/sip/articles/554-ims-standard-standards-bodies.htm>.
- [19] "Verizon snowstorm outage," [Online]. Available: <https://www.verizon.com/about/news/verizon-response-coast-to-coast-winter-storms>.
- [20] "Improper Hardware Disposal contributing to Data breaches," [Online]. Available: <https://eridirect.com/blog/2017/11/how-does-hardware-contribute-to-data-breaches/>.

- [21] "KDDI outage affects nearly 40M in Japan," [Online]. Available: <https://www.fierce-network.com/wireless/kddi-outage-affects-nearly-40m-customers-japan>.
- [22] "Circuit failure that set off a chain of events leading to major capacity issues across T-Mobile's IMS core network," [Online]. Available: <https://www.fierce-network.com/operators/t-mobile-network-outage-triggered-by-fiber-circuit-failure>.
- [23] "AT&T Upgrade Failure," [Online]. Available: <https://arstechnica.com/tech-policy/2024/02/atts-botched-network-update-caused-yesterdays-major-wireless-outage/>.
- [24] "911 Firewall Outage," [Online]. Available: <https://arstechnica.com/tech-policy/2024/06/faulty-firewall-blocked-911-calls-throughout-massachusetts-for-two-hours/>.
- [25] "Microsoft Electrical distribution system failure," [Online]. Available: <https://www.datacenterdynamics.com/en/news/electrical-distribution-system-failure-causes-outage-at-microsoft-data-center/>.
- [26] "AT&T Breach," [Online]. Available: <https://krebsonsecurity.com/2024/07/hackers-steal-phone-sms-records-for-nearly-all-att-customers/>.
- [27] "Telstra critical voice services," [Online]. Available: <https://www.itnews.com.au/news/telstra-trials-way-to-keep-eftpos-critical-voice-services-working-during-outages-605265>.
- [28] "Rogers Communications Canada IMS-caused Network Outage," [Online]. Available: <https://urgentcomm.com/2022/09/20/reflections-on-recent-lte-outages/>.
- [29] "Expired Ericsson Certificate," [Online]. Available: <https://www.zdnet.com/article/ericsson-expired-certificate-caused-o2-and-softbank-outages/>.
- [30] GSMA, "FS.11 SS7 Interconnect Security Monitoring and Firewall Guidelines".
- [31] GSMA, "FS.19 Diameter Interconnect Security".
- [32] "T-Mobile API Breach," [Online]. Available: <https://www.cnet.com/tech/mobile/another-data-breach-has-hit-t-mobile-impacting-37-million-accounts/>.
- [33] "Optus API breach," [Online]. Available: <https://www.theguardian.com/business/2022/sep/29/optus-data-breach-everything-we-know-so-far-about-what-happened>.
- [34] "2023 T-Mobile API breach," [Online]. Available: <https://www.csoonline.com/article/574385/t-mobile-suffers-8th-data-breach-in-less-than-5-years.html>.
- [35] "Sophos HSM Flaw," [Online]. Available: <https://news.sophos.com/en-us/2019/06/11/researchers-crack-digital-safe-using-hsm-flaw/>.
- [36] "Global STIR/SHAKEN Is Dead; What Comes Next?," [Online]. Available: <https://commsrisk.com/global-stir-shaken-is-dead-what-comes-next/>.
- [37] "IMS Server Vulnerabilities," [Online]. Available: <https://onlinelibrary.wiley.com/doi/10.1155/2022/7395128>.
- [38] "Swisscom turns off 2G as Cosmote plans to turn off 3G," [Online]. Available: <https://www.capacitymedia.com/article/29otd15ias3ir9ekzxs74/news/swisscom-turns-off-2g-as-cosmote-plans-to-turn-off-3g>.

- [39] "Security Threats to Voice Services in 5G Standalone Networks," [Online]. Available: https://www.researchgate.net/publication/363268721_Security_Threats_to_Voice_Services_in_5G_Standalone_Networks.
- [40] "IMSI Catchers in the wild: A real world 4G/5G assessment," [Online]. Available: <https://www.sciencedirect.com/science/article/abs/pii/S1389128621002061>.
- [41] "A Comprehensive Study of Top-Tier Carriers Across Asia and North America Reveals Potential for Call DoS Attacks and Suggests Effective Solutions," [Online]. Available: <https://par.nsf.gov/servlets/purl/10356375>.